

OWASP Juice Shop — Burp Suite

Lectura de 13 minutos · 24 de febrero de 2023



Ramadán Salman

Follow



Listen



Compartir

Esta sala utiliza la aplicación web vulnerable Juice Shop para aprender a identificar y explotar vulnerabilidades comunes en las aplicaciones web.

¡Trataremos los siguientes temas!

Inyección

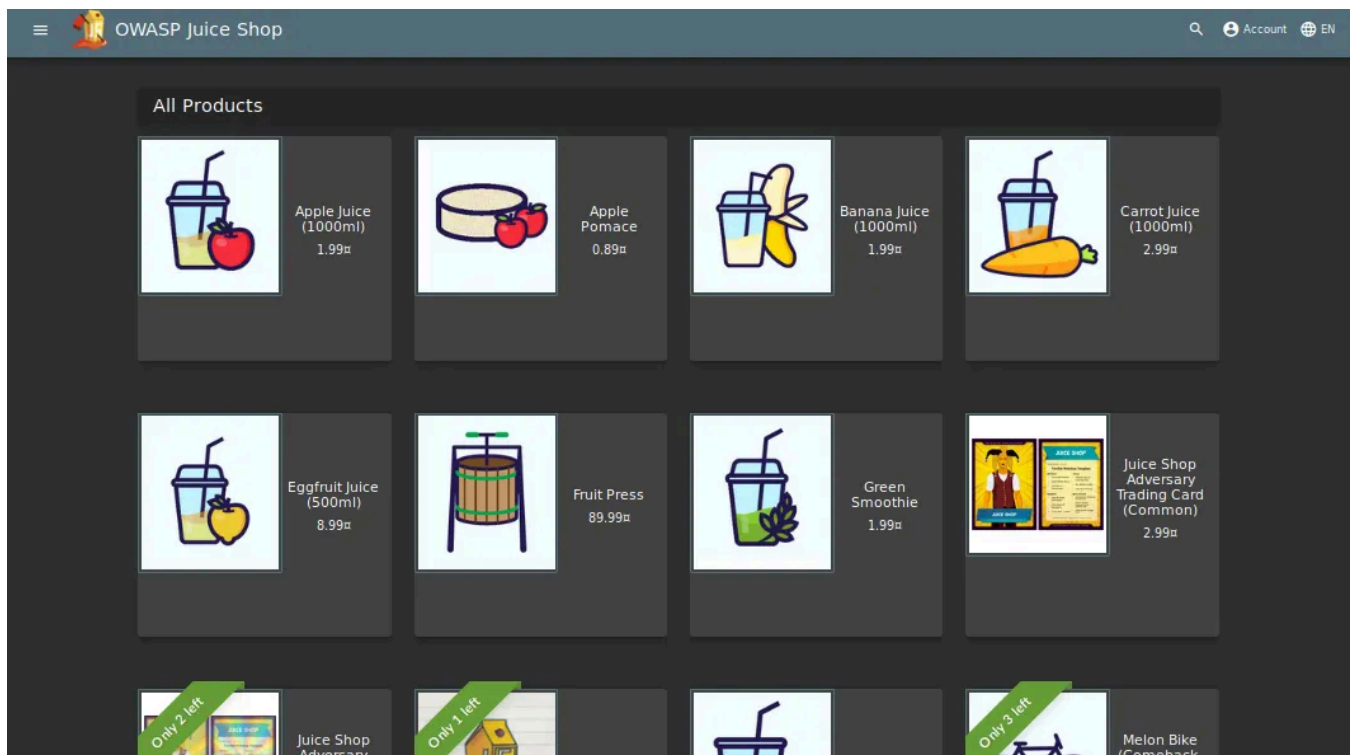
Autenticación defectuosa

Exposición de datos sensibles

Control de acceso roto

Secuencias de comandos entre sitios (XSS)

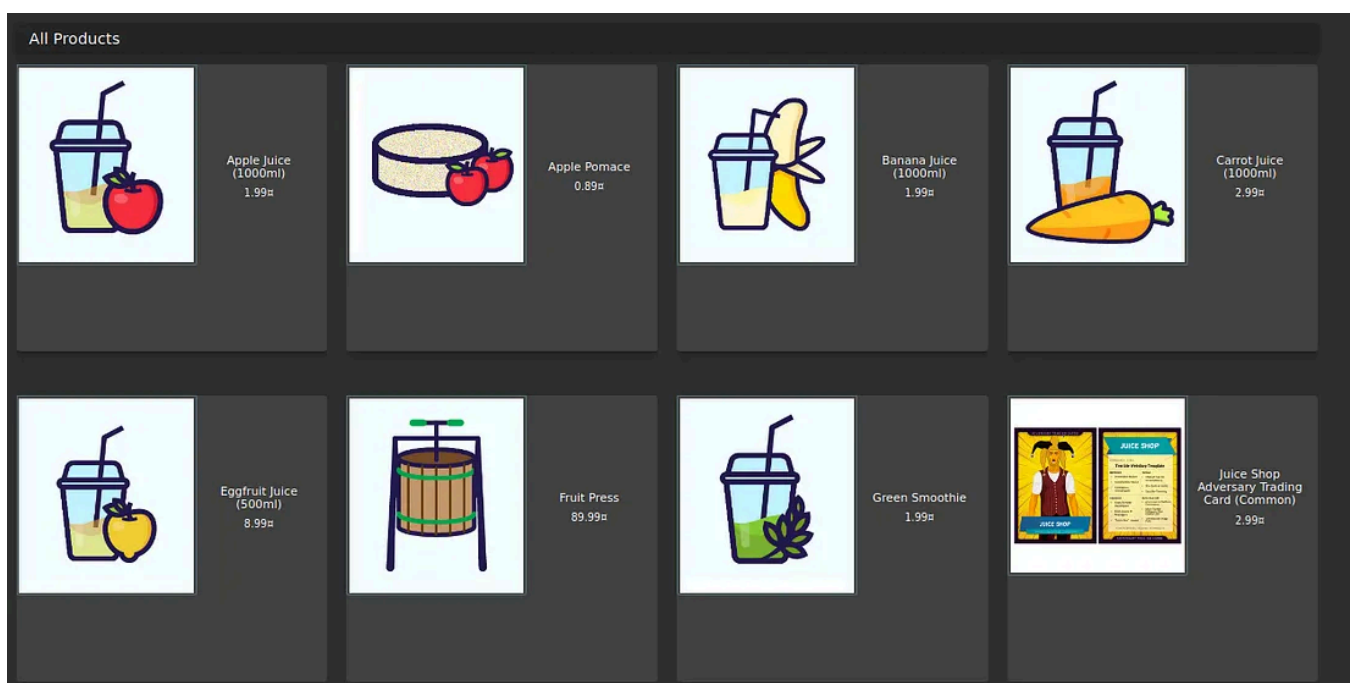
Tarea 1 ¡Vamos de aventura!



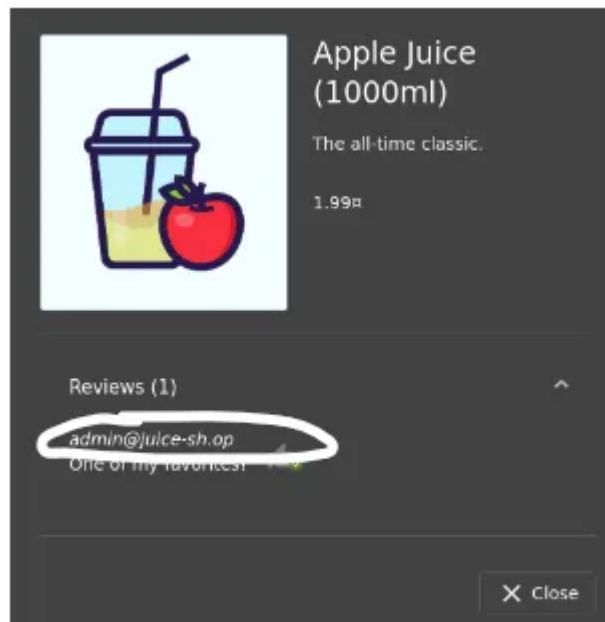
Antes de entrar en materia, conviene echar un vistazo al sitio. En Burp, desactiva el modo Intercept y navega por la página. Esto permite que Burp registre las distintas solicitudes del servidor, información que podría ser útil más adelante.

Esto se llama **recorrer** la aplicación, ¡lo cual también es una forma de **reconocimiento** !

Pregunta nº 1: ¿Cuál es la dirección de correo electrónico del administrador?

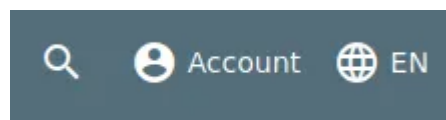


Las reseñas muestran la dirección de correo electrónico de cada usuario. ¡Al hacer clic en el producto Zumo de Manzana, se muestra el correo electrónico del administrador!



admin@juice-sh.op

Pregunta n.º 2: ¿Qué parámetro se utiliza para la búsqueda?

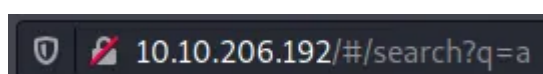


Haz clic en la lupa que se encuentra en la parte superior derecha de la aplicación y aparecerá una barra de búsqueda.



A continuación, podemos introducir un texto y, al pulsar **Enter**, buscará el texto que acabamos de introducir.

Ahora presta atención a la URL, que se actualizará con el texto que acabamos de introducir.



Ahora podemos ver el parámetro de búsqueda después de `/#/search?` la letra **q**

Pregunta n.º 3: ¿A qué programa hace referencia Jim en su reseña?

Jim hizo una reseña del producto Green Smoothie. Podemos ver que menciona un replicador.



[Abrir en la aplicación](#) ↗

[Inscribirse](#)

[Iniciar sesión](#)

Medium

🔍 Buscar

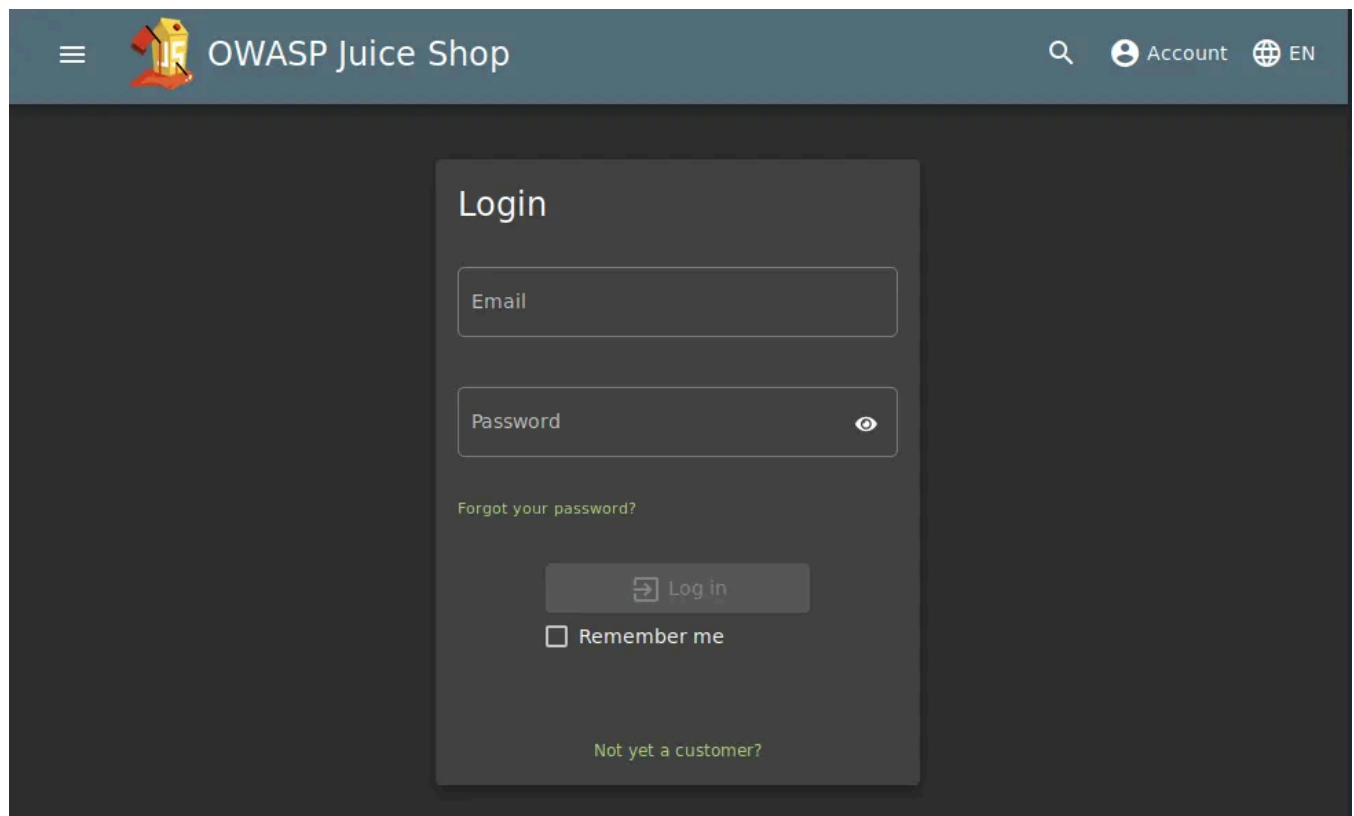


Si buscamos " **replicador** " en Google, obtendremos resultados que indican que proviene de una serie de televisión llamada Star Trek.



Respuesta: Star Trek

Tarea 2 Inyectar el jugo



Esta tarea se centrará en las vulnerabilidades de inyección. Estas vulnerabilidades son muy peligrosas para una empresa, ya que pueden provocar interrupciones en el servicio y/o pérdida de datos. Identificar los puntos de inyección en una aplicación web suele ser bastante sencillo, ya que la mayoría devuelven un error. Existen muchos tipos de ataques de inyección; algunos de ellos son:

Inyección SQL:

La inyección SQL se produce cuando un atacante introduce una consulta maliciosa o con formato incorrecto para recuperar o manipular datos de una base de datos. En algunos casos, también puede permitir el acceso no autorizado a cuentas.

Pero en nuestro caso, utilizaremos **la inyección SQL**.

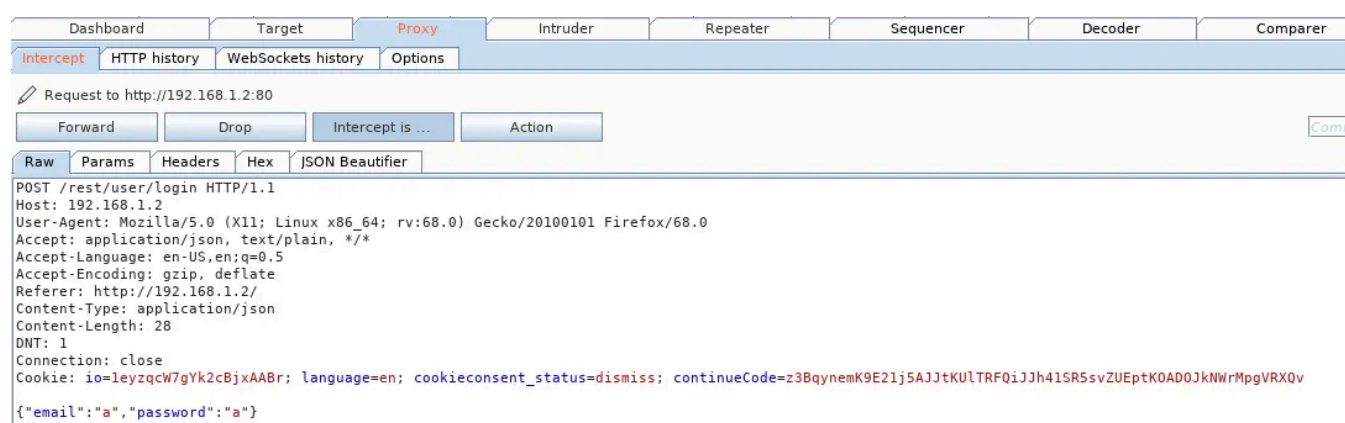
Pregunta n.º 1: ¡Inicie sesión en la cuenta de administrador!

Una vez que accedamos a la página de inicio de sesión, introduzca algunos datos en los campos de correo electrónico y contraseña.

Intercept is on

Antes de hacer clic en enviar, asegúrese de que el modo Interceptar esté activado.

¡Esto nos permitirá ver los datos que se envían al servidor!

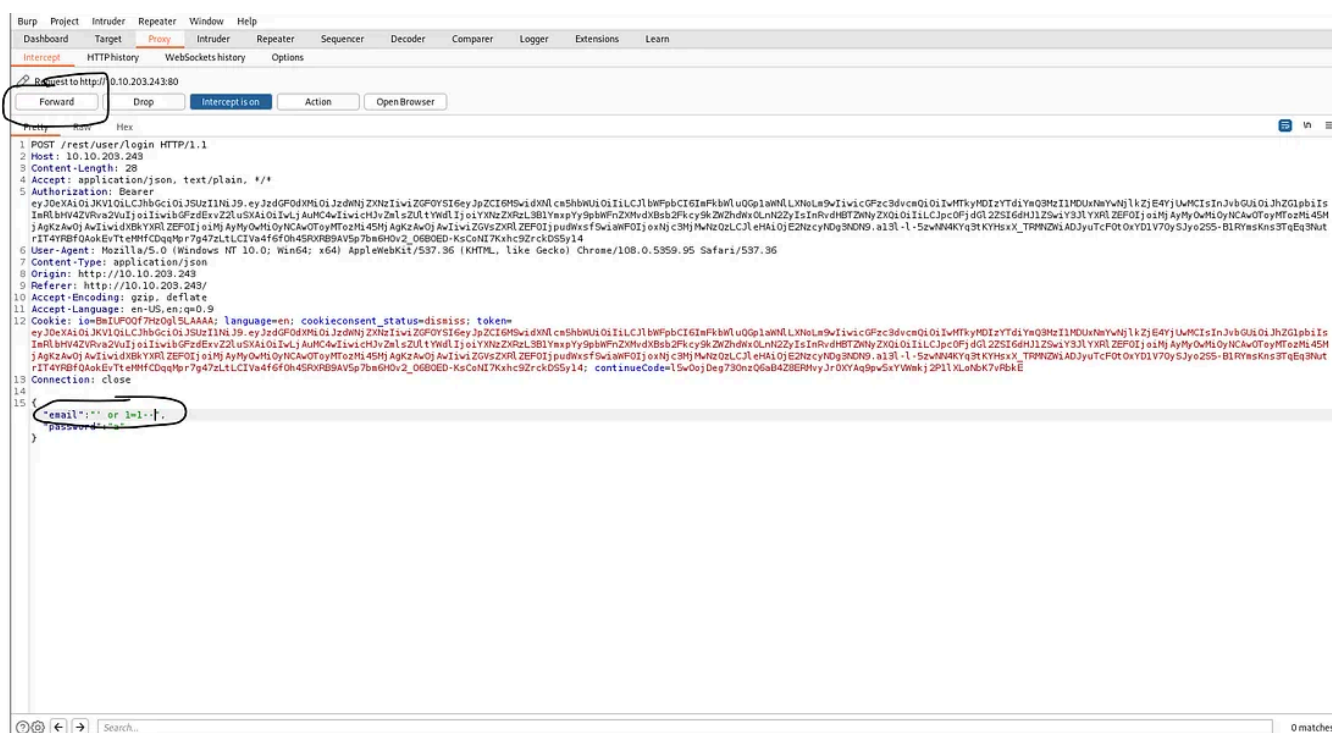


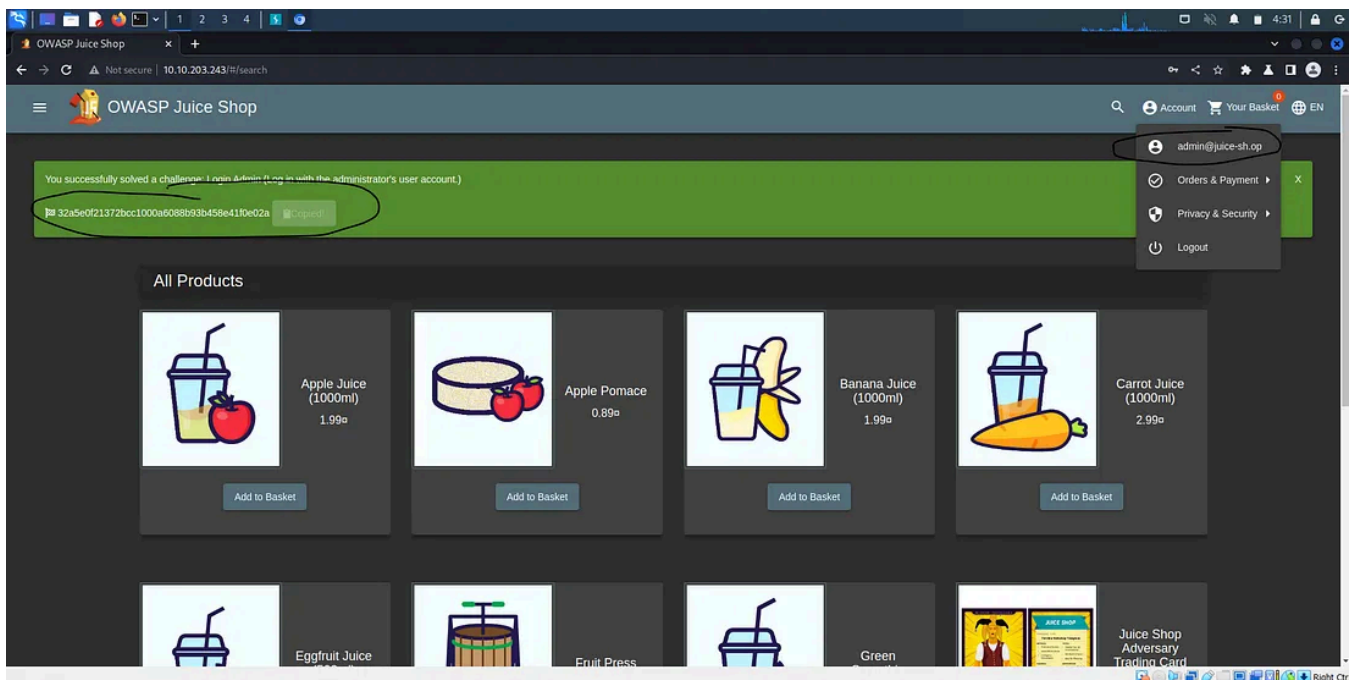
Ahora cambiaremos la “a” junto al correo electrónico por: ' o 1=1 — y lo reenviaremos al servidor.

```
{"email":"' or 1=1--", "password": "a"}
```

¿Por qué funciona esto?

1. El carácter ' cerrará los paréntesis en la consulta SQL.
2. 'OR' in a SQL statement will return true if either side of it is true. As `1=1` is **always true**, the whole statement is true. Thus it will tell the server that the email is valid, and log us into **user id 0**, which happens to be the administrator account.
3. The `--` character is used in SQL to comment out data, any restrictions on the login will no longer work as they are interpreted as a comment. This is like the `#` and `//` comment in python and javascript respectively.





Answer: 32a5e0f21372bcc1000a6088b93b458e41f0e02a

Question #2: Log into the Bender account!

Similar to what we did in **Question #1**, we will now log into Bender's account!

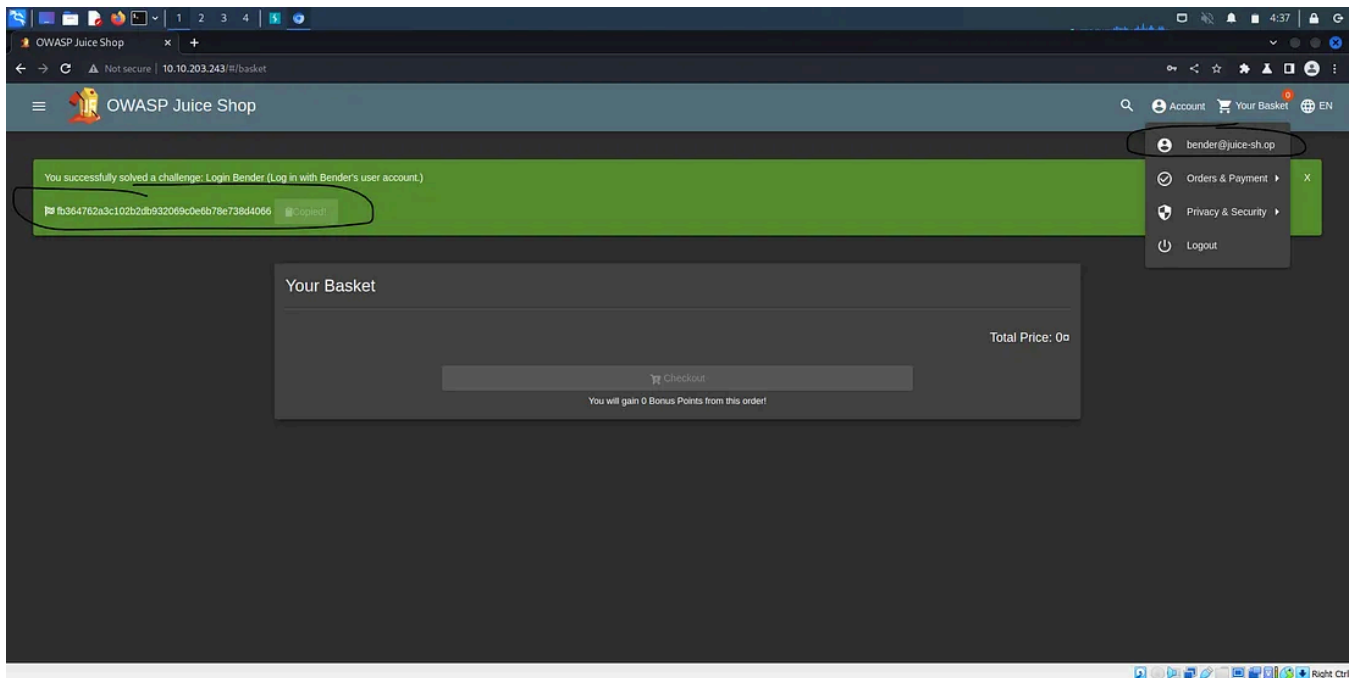
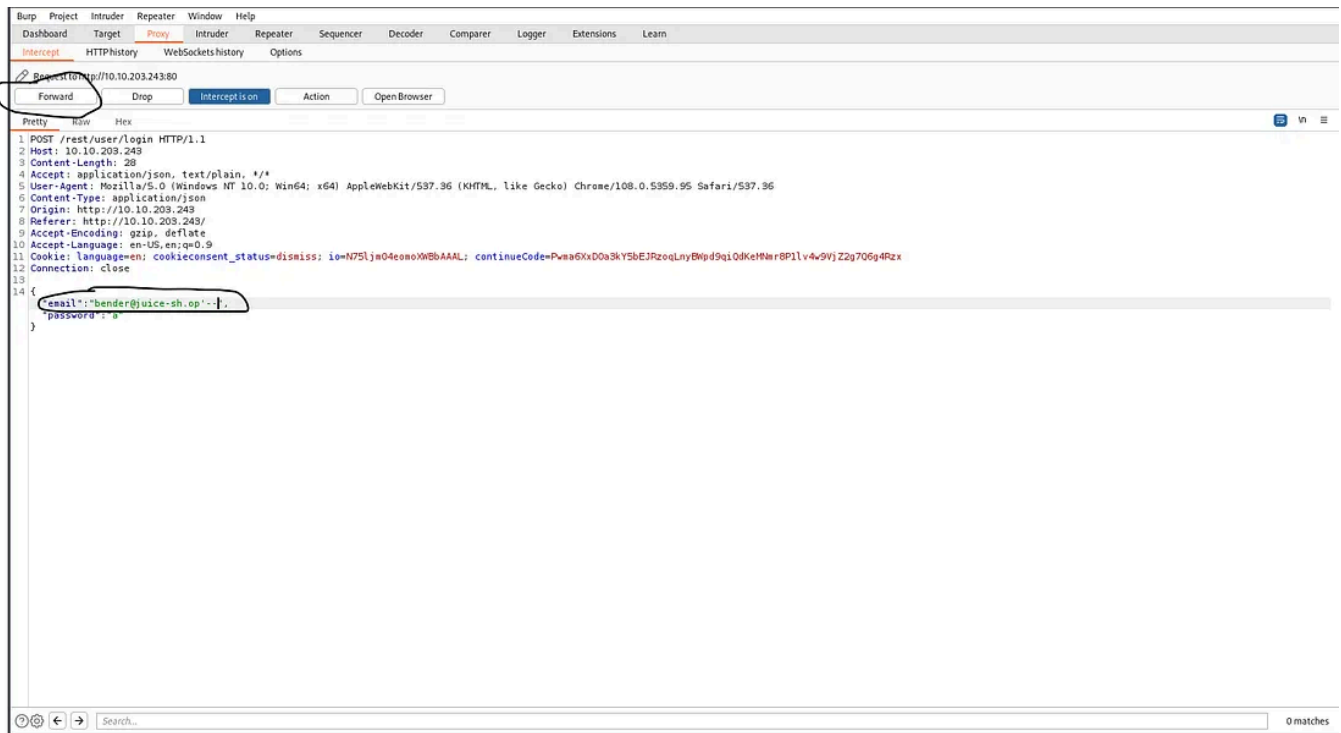
Capture the login request again, but this time we will put: **bender@juice-sh.op'** — as the email.

```
{"email": "bender@juice-sh.op' --", "password": "a"}
```

Now, forward that to the server!

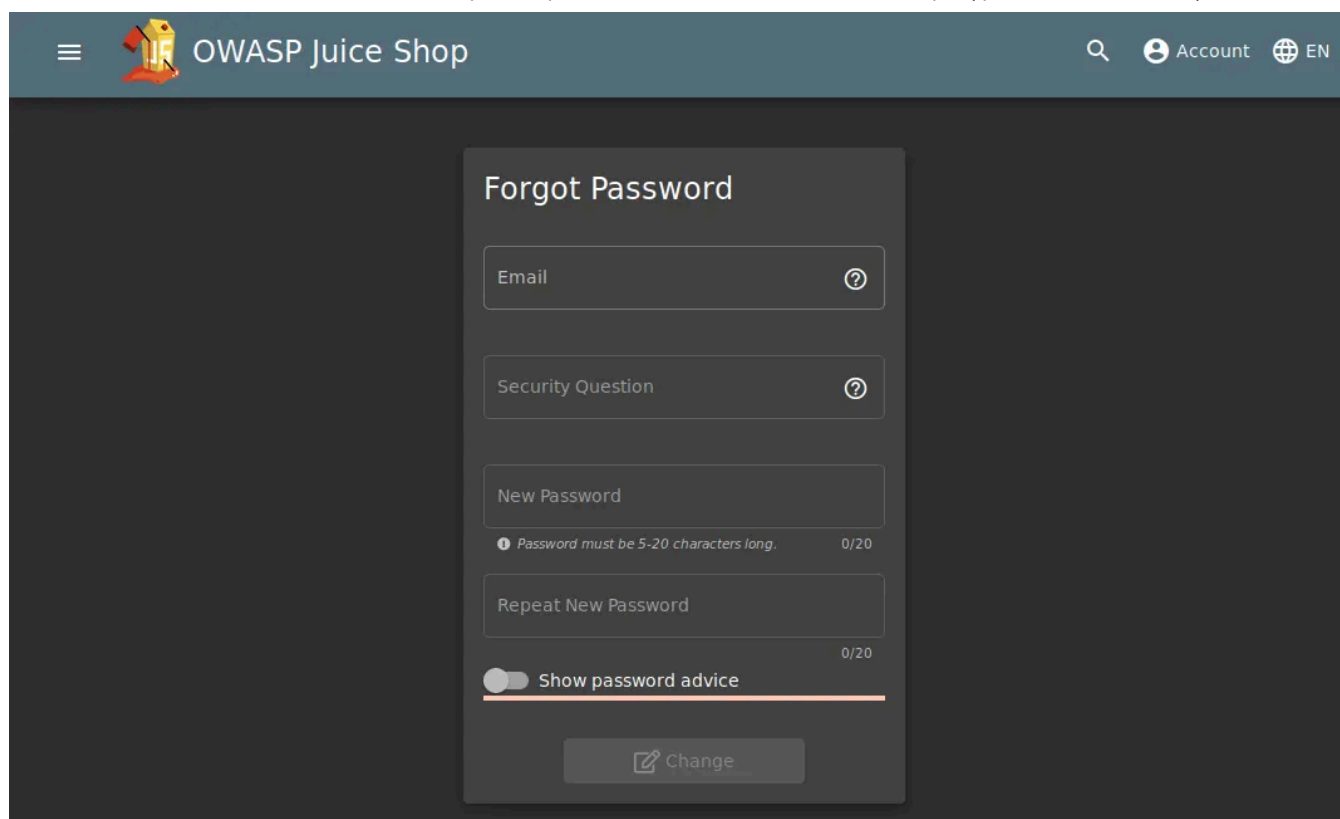
But why don't we put the 1=1?

Well, as the email address is valid (which will return **true**), we do not need to force it to be **true**. Thus we are able to use ' — to bypass the login system. Note that 1=1 can be used when the email or username is not known or is invalid.



Answer: fb364762a3c102b2db932069c0e6b78e738d4066

Task 4 Who broke my lock?!

The image shows a web browser window displaying the OWASP Juice Shop interface. The header bar is dark blue with the OWASP Juice Shop logo on the left and search, account, and language (EN) icons on the right. The main content area is dark grey. In the center, there is a white 'Forgot Password' form. The form contains four input fields: 'Email', 'Security Question', 'New Password', and 'Repeat New Password'. The 'New Password' field has a feedback message: 'Password must be 5-20 characters long.' and a character count '0/20'. The 'Repeat New Password' field also has a character count '0/20'. Below the input fields is a toggle switch labeled 'Show password advice'. At the bottom of the form is a 'Change' button with a pencil icon.

In this task, we will look at exploiting authentication through different flaws. When talking about flaws within authentication, we include mechanisms that are vulnerable to manipulation. These mechanisms, listed below, are what we will be exploiting.

- Weak passwords in high-privileged accounts
- Forgotten password pages

Question #1: Bruteforce the Administrator account's password!

We have used SQL Injection to log into the Administrator account but we still don't know the password. Let's try a brute-force attack! We will once again capture a login request, but instead of sending it through the proxy, we will send it to Intruder.

Go to Positions and then select the **Clear \$** button. In the password field place two \$ inside the quotes. To clarify, the \$ \$ is not two separate inputs but rather Burp's implementation of quotations e.g. `""`. The request should look like the image below.

Target Positions Payloads Options

⑦ Payload Positions

Configure the positions where payloads will be inserted into the base request. The attack type determines the way in which payloads are assigned to payload positions - see help for full details.

Attack type:

```
POST /rest/user/login HTTP/1.1
Host: 192.168.1.2
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.1.2/
Content-Type: application/json
Content-Length: 44
DNT: 1
Connection: close
Cookie: io=iUcyNra0oP5tgC-LAAcQ; language=en; cookieconsent_status=dismiss; continueCode=WV2ov8DrgwPX7AD6tpUyTWFOHV1QSKKh2qSpJsDzU3jIw0GRQ9lYbyLZqM4l
{"email":"admin@juice-sh.op","password":"$5$"}

```

For the payload, we will be using the **best1050.txt** from Seclists. (Which can be installed via: **apt-get install seclists**)

You can load the list from: /usr/share/wordlists/SecLists/Passwords/Common-Credentials/best1050.txt

Applications Places System Fri 24 Feb, 10:19 AttackBox IP:10.10.202.226

Burp Suite Community Edition v2022.9.5 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

1 x 2 x +

Positions Payloads Resource Pool Options

⑦ Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: Payload count: 1,050
Payload type: Request count: 1,050

⑦ Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load

Remove

Clear

Deduplicate

Add

0

00000

000000

0000000

00000000

0987654321

1

1111

11111

1

Add from list... (Pro version only)

⑦ Payload Processing

You can define rules to perform various processing tasks on each payload before it is used.

Add

Edit

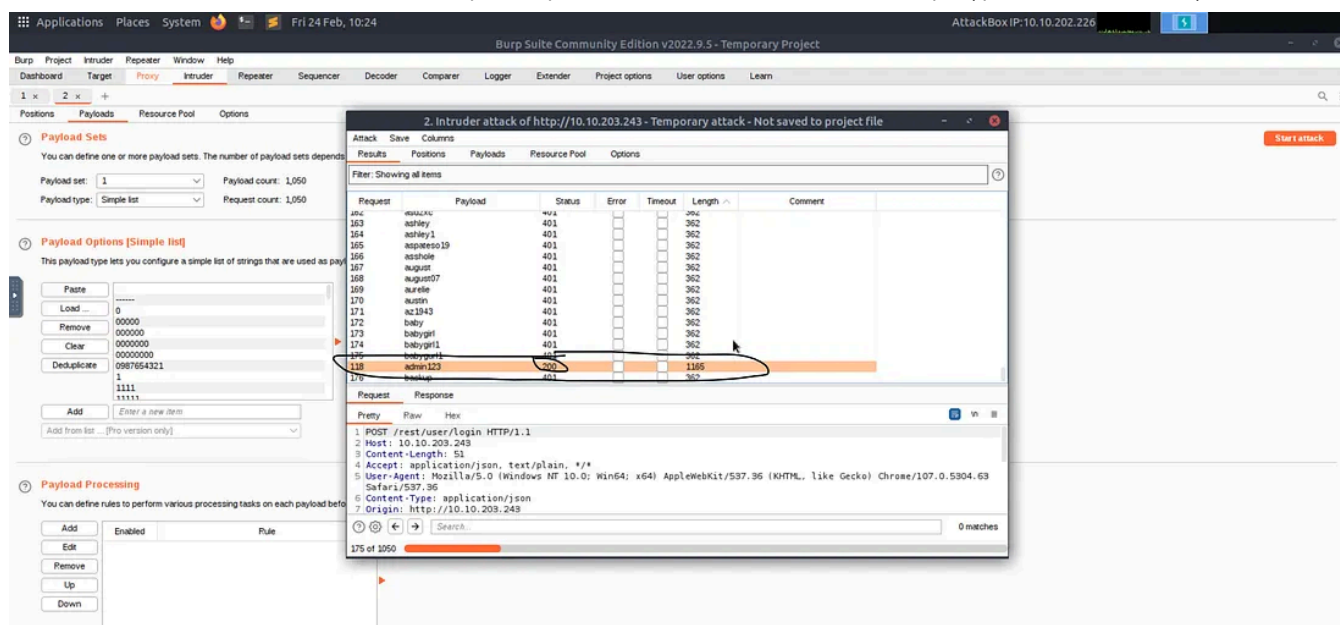
Remove

Up

Down

Enabled

Rule



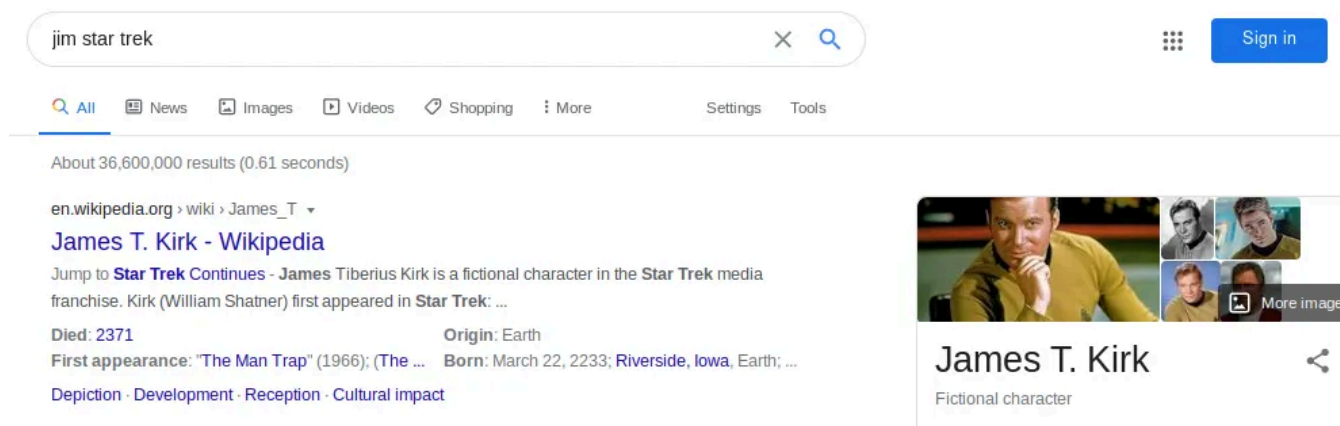
Password: admin123

Answer: c2110d06dc6f81c67cd8099ff0ba601241f1ac0e

Question #2: Reset Jim's password!

Believe it or not, the reset password mechanism can also be exploited! When inputted into the email field in the Forgot Password page, Jim's security question is set to "Your eldest sibling's middle name?".

In Task 2, we found that Jim might have something to do with Star Trek. Googling "Jim Star Trek" gives us a wiki page for **Jame T. Kirk** from Star Trek.



Looking through the wiki page we find that he has a brother.

Family	George Kirk (father)
	Winona Kirk (mother)
	George Samuel Kirk (brother)
	Tiberius Kirk (grandfather)
	James (maternal grandfather)

Looks like his brother's middle name is **Samuel**

Inputting that into the Forgot Password page allows you to successfully change his password.

You can change it to anything you want!

Forgot Password

Email

Security Question

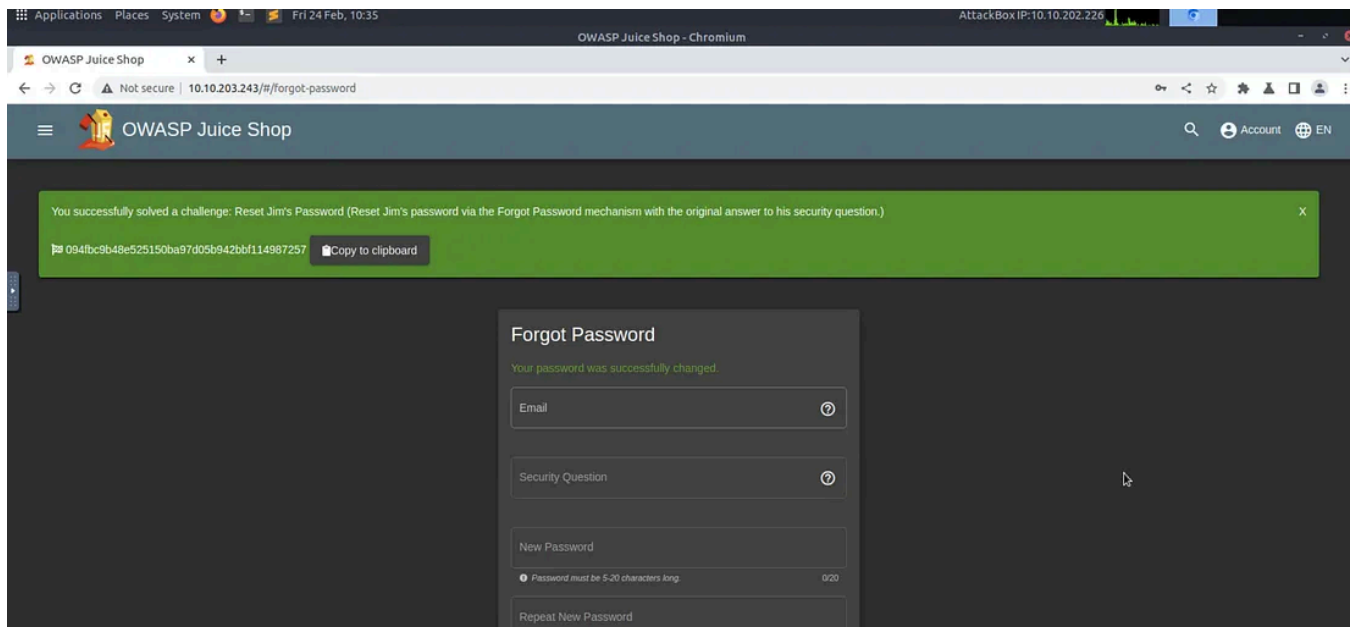
New Password

Password must be 5-20 characters long. 5/20

Repeat New Password

5/20

☐ Show password advice



Answer: 094fbc9b48e525150ba97d05b942bbf114987257

Task 5 AH! Don't look!

About Us

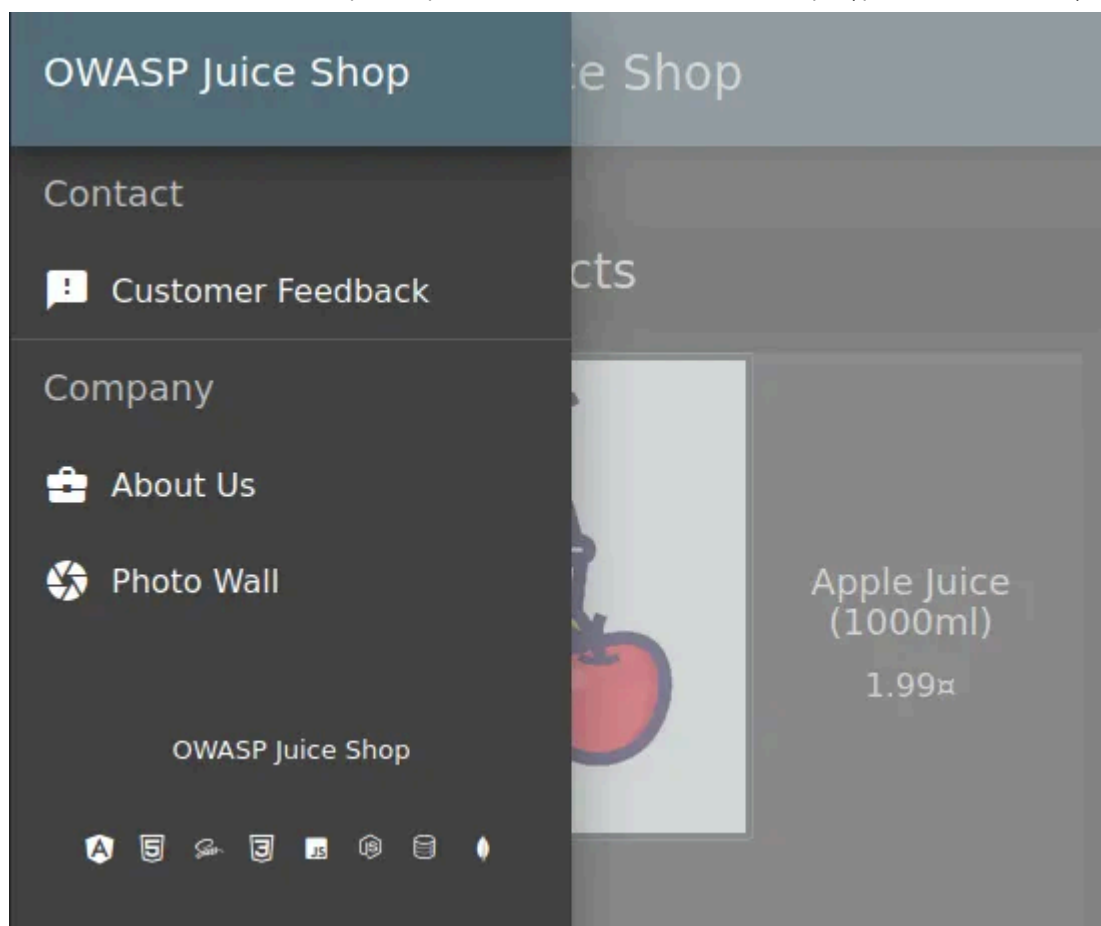
Corporate History & Policy

Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. Duis autem vel eum iriure dolor in hendrerit in vulputate velit esse molestie consequat, vel illum dolore eu feugiat nulla facilisis at vero eros et accumsan et iusto odio dignissim qui blandit praesent luptatum zzril delenit augue duis dolore te feugait nulla facilisi. Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed diam nonummy nibh euismod tincidunt ut laoreet dolore magna aliquam erat volutpat. [Check out our boring terms of use if you are interested in such lame stuff.](#) At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, At accusam aliquyam diam diam dolore dolores duo eirmod eos erat, et nonumy sed tempor et et invidunt justo labore Stet clita ea et gubergren, kasd magna no rebum.

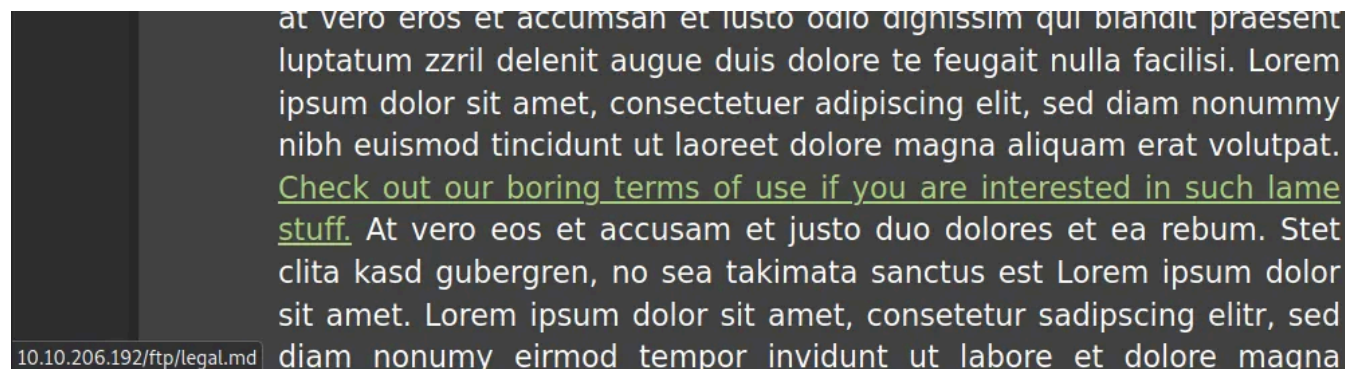
A web application should store and transmit sensitive data safely and securely. But in some cases, the developer may not correctly protect their sensitive data, making it vulnerable.

Most of the time, data protection is not applied consistently across the web application making certain pages accessible to the public. Other times information is leaked to the public without the knowledge of the developer, making the web application vulnerable to an attack.

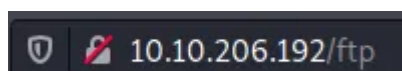
Question #1: Access the Confidential Document!

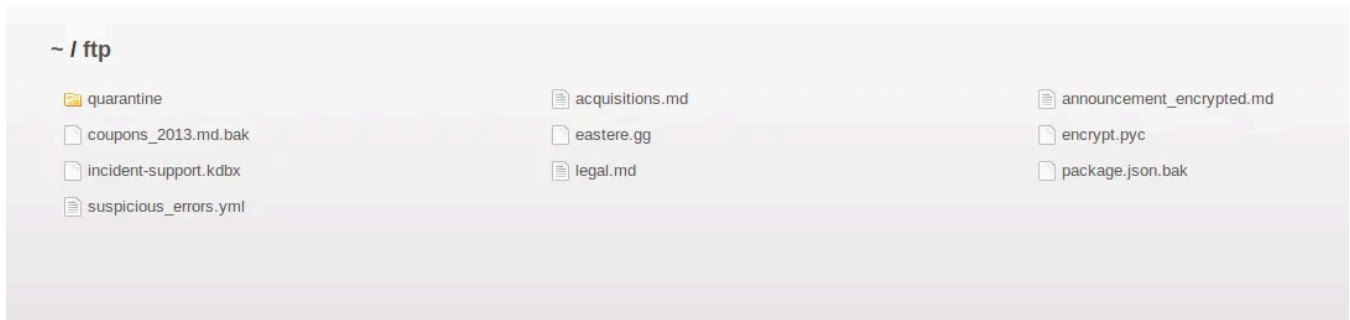


Navigate to the **About Us** page, and hover over the “*Check out our terms of use*”.



You will see that it links to <http://10.10.203.243/ftp/legal.md>. Navigating to that **/ftp/** directory reveals that it is exposed to the public!





Yes, as we guessed there are some files here that we normally shouldn't be able to see. Now what we need to do is download acquisitions.md file and go back to the homepage.

Answer: edf9281222395a1c5fee9b89e32175f1ccf50c5b

Question #2: Log into MC SafeSearch's account!

<https://youtu.be/v59CX2DiX0Y>

After watching the video there are certain parts of the song that stand out.

Get Ramazan Salman's stories in your inbox

Join Medium for free to get updates from this writer.

Introduce tu correo electrónico

Suscribir

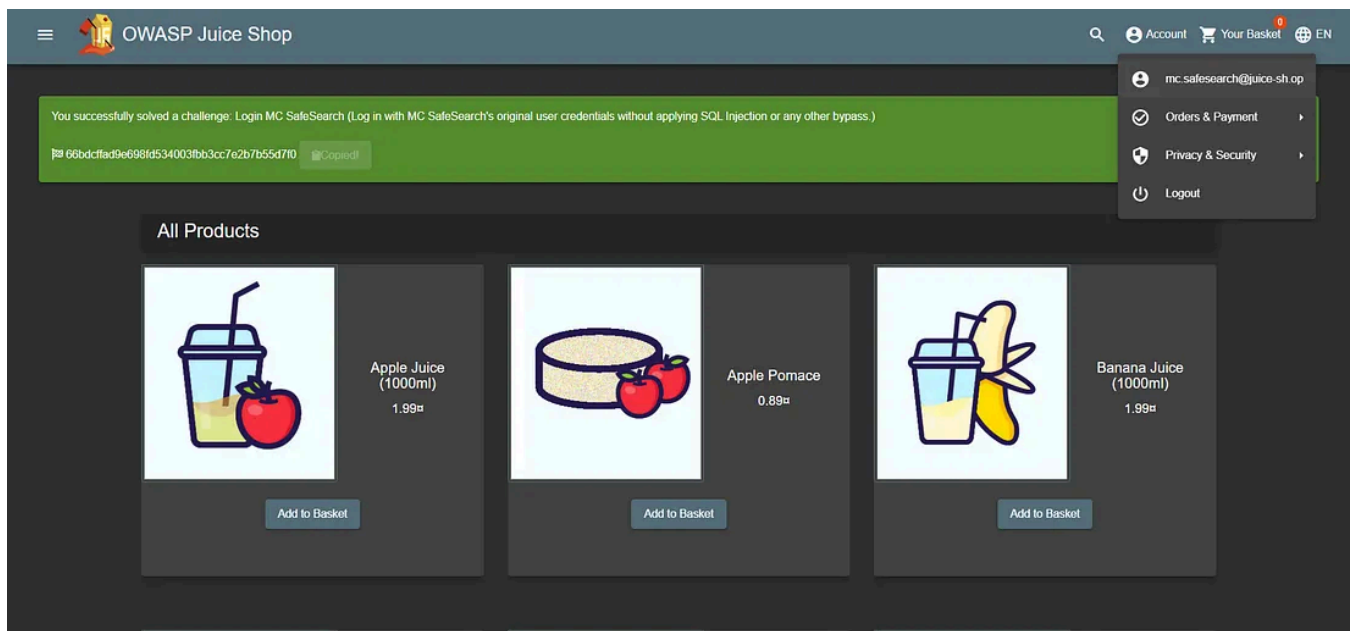
☐ Remember me for faster sign in

He notes that his password is “**Mr. Noodles**” but he has replaced some “**vowels into zeros**”, meaning that he just replaced the o's into 0's.

We now know the password to the *mc.safesearch@juice-sh.op* account is “**Mr. N00dles**”

email: mc.safesearch@juice-sh.op

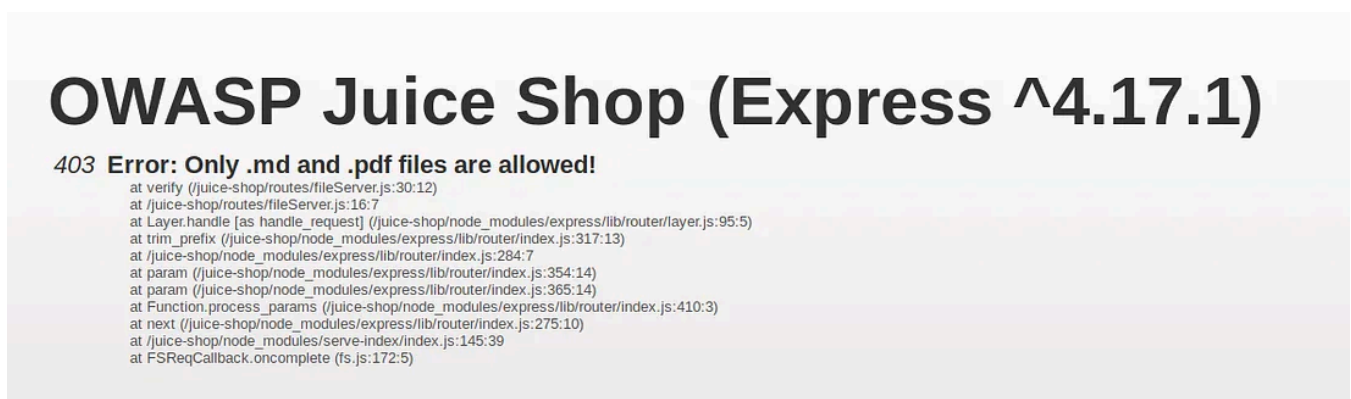
password: Mr. N00dles



Answer: 66bdcffad9e698fd534003fbb3cc7e2b7b55d7f0

Question #3: Download the Backup file!

We will now go back to the <http://machineip/ftp/> folder and try to download **package.json.bak**. But it seems we are met with a 403 which says that only .md and .pdf files can be downloaded.



To get around this, we will use a character bypass called “Poison Null Byte”. A Poison Null Byte looks like this: **%00**.

Note: as we can download it using the url, we will need to encode this into a url encoded format.

The Poison Null Byte will now look like this: **%2500**. Adding this and then a **.md** to the end will bypass the 403 error!

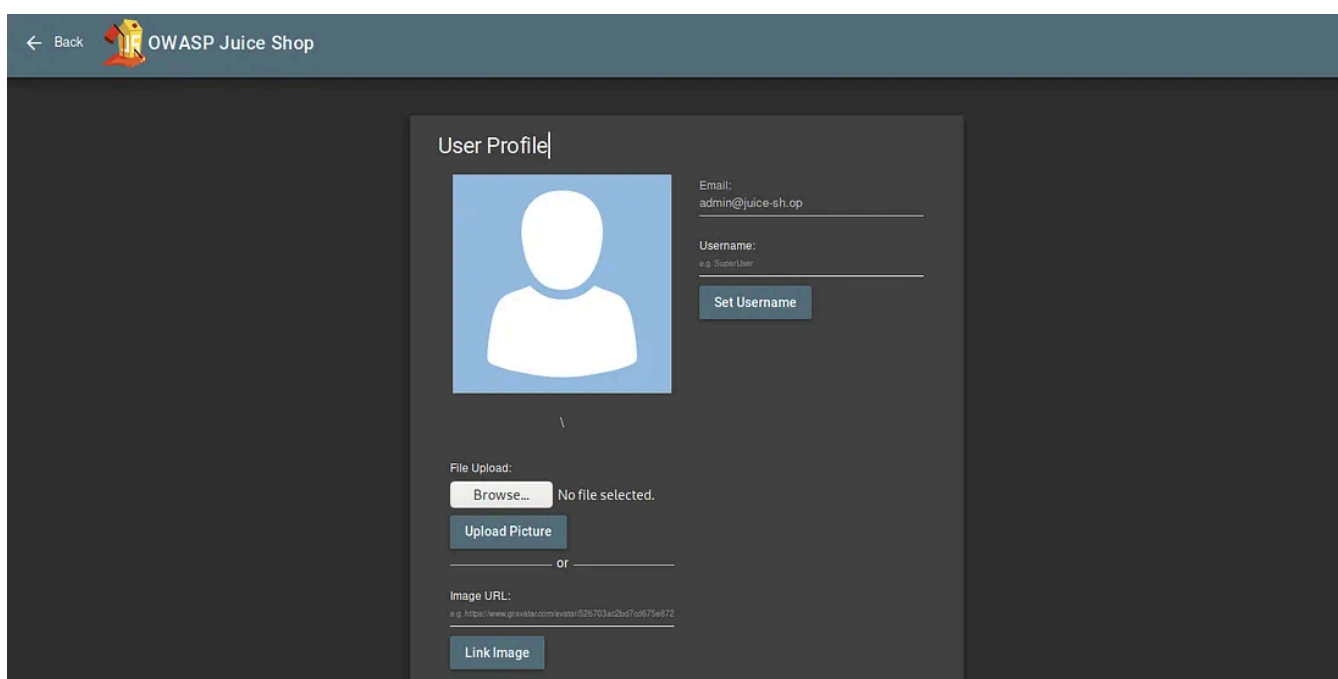
10.10.206.192/ftp/package.json.bak%2500.md

To summarize what we've done here, we first saw that page doesn't allow us to download files if their extensions of them are not md or pdf. Then we decided to add .md or .pdf at the end of the URL but if pressed enter directly after we'd get nothing because there is no such file named package.json.bak.md . So in order to bypass that we need to make the server ignore the rest of the file names after it sees bak. And we did it with URL encoded null byte(%2500). Thus we defined the file name in the URL and bypassed the checking mechanism successfully.

After you've downloaded the file, return to the homepage you'll see a flag there.

Answer: bfc1e6b4a16579e85e06fee4c36ff8c02fb13795

Task 6 Who's flying this thing?



Modern-day systems will allow multiple users to have access to different pages. Administrators most commonly use an administration page to edit, add and remove different elements of a website. You might use these when you are building a website with programs such as Weebly or Wix.

When Broken Access Control exploits or bugs are found, they will be categorized into one of **two types**:

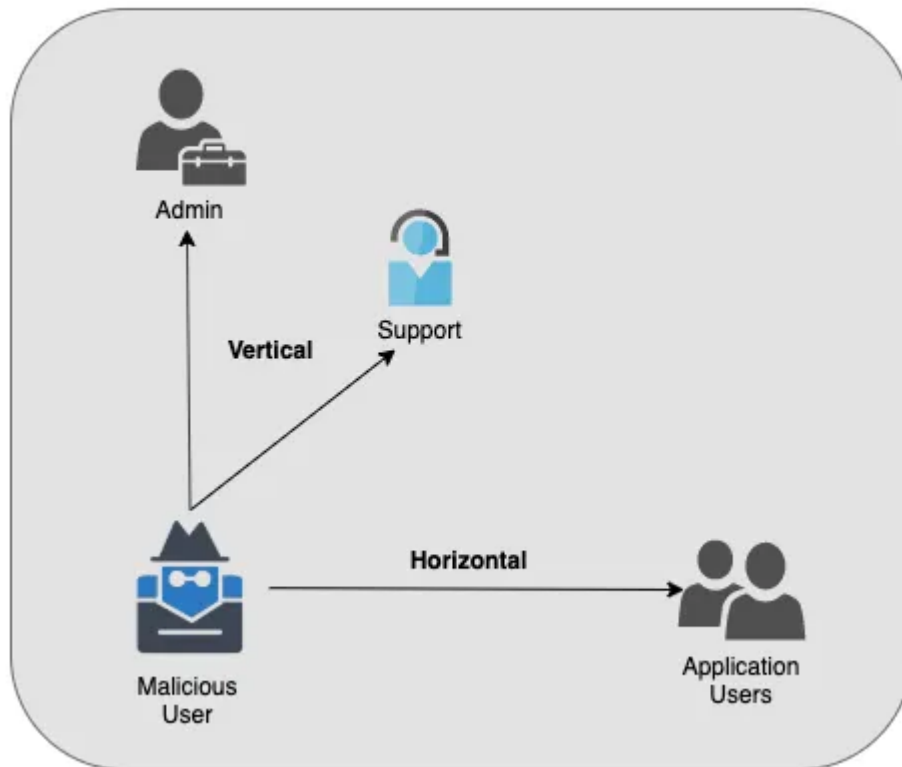
Horizontal Privilege Escalation

Occurs when a user can perform an action or access data of another user with the **same** level of permissions.

Vertical Privilege Escalation

Occurs when a user can perform an action or access data of another user with a **higher** level of permissions.

Broken Access Control

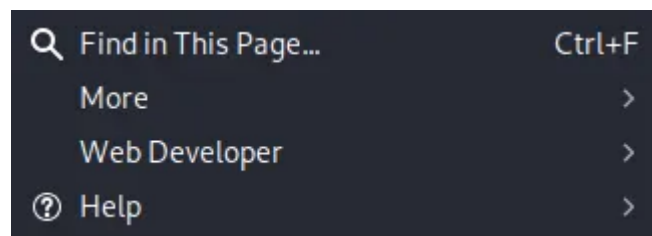


Credits: Packetlabs.net

Question #1: Access the administration page!

First, we are going to open the **Debugger** on **Firefox**.

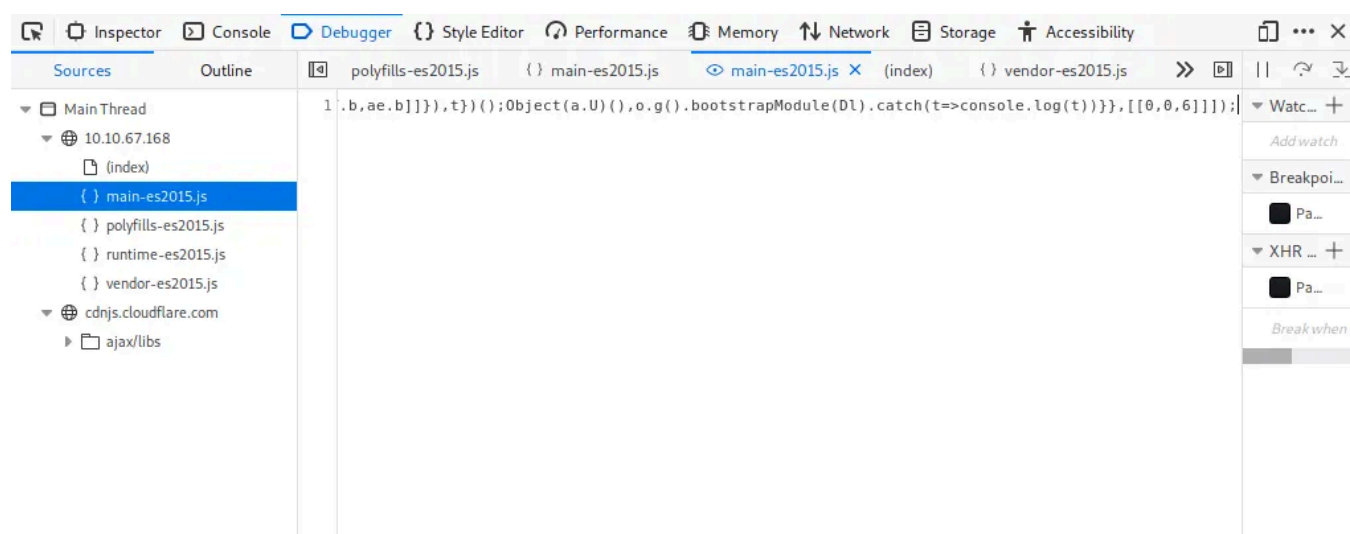
This can be done by navigating to it in the Web Developers menu.



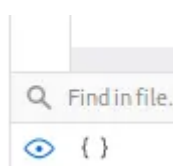
Toggle Tools	Ctrl+Shift+I
Inspector	Ctrl+Shift+C
Web Console	Ctrl+Shift+K
Debugger	
Style Editor	Shift+F7

We are then going to refresh the page and look for a javascript file for **main-es2015.js**

We will then go to that page at: <http://machineip/main-es2015.js>



To get this into a format we can read, click the `{ }` button at the bottom



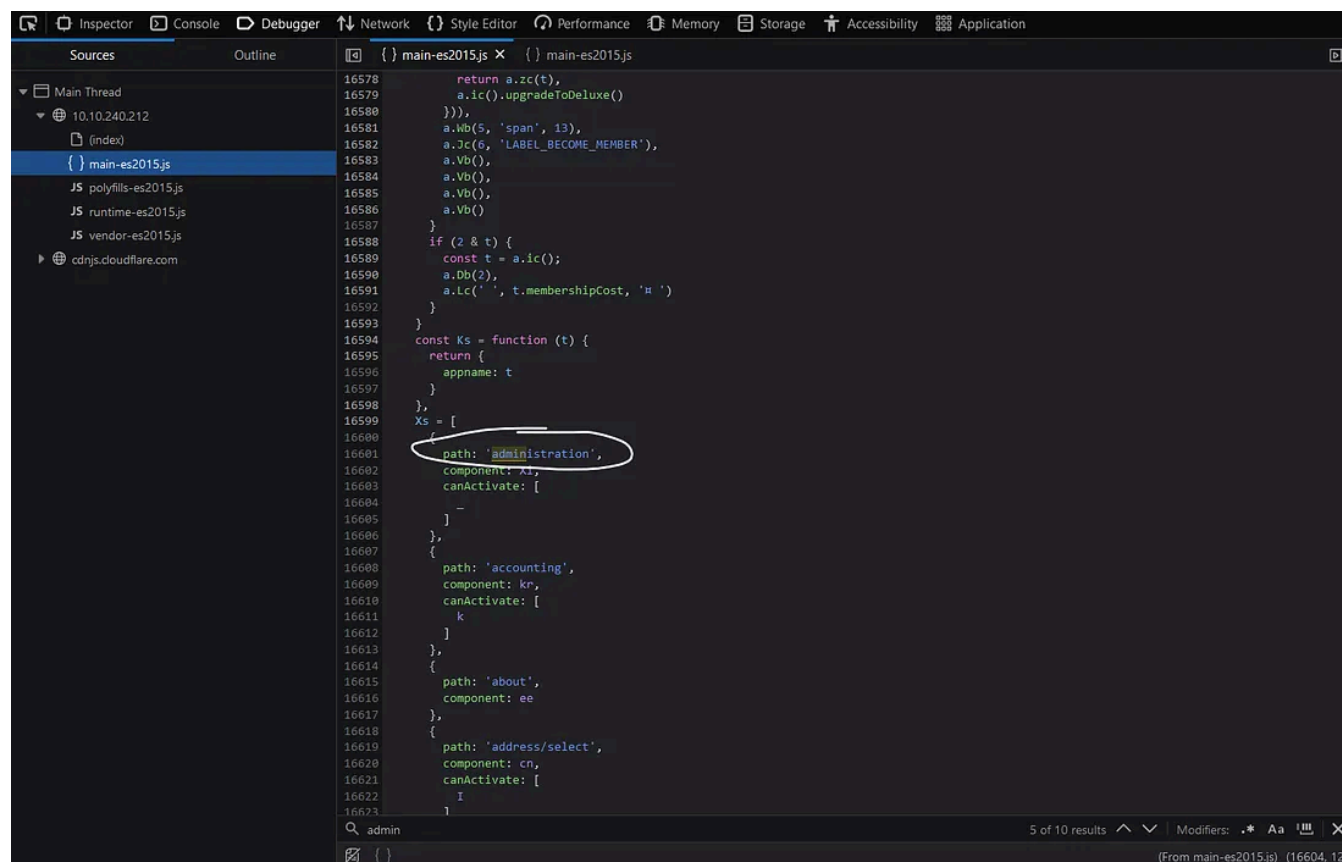
Now search for the term “admin”

You will come across a couple of different words containing “admin” but the one we are looking for is “path: administration”

This hints towards a page called “**/#/administration**” as can be seen by the **about** path a couple of lines below, but going there while not logged in doesn’t work.

As this is an Administrator page, it makes sense that we need to be in the **Admin account** in order to view it.

A good way to stop users from accessing this is to only load parts of the application that need to be used by them. This stops sensitive information such as an admin page from being leaked or viewed.



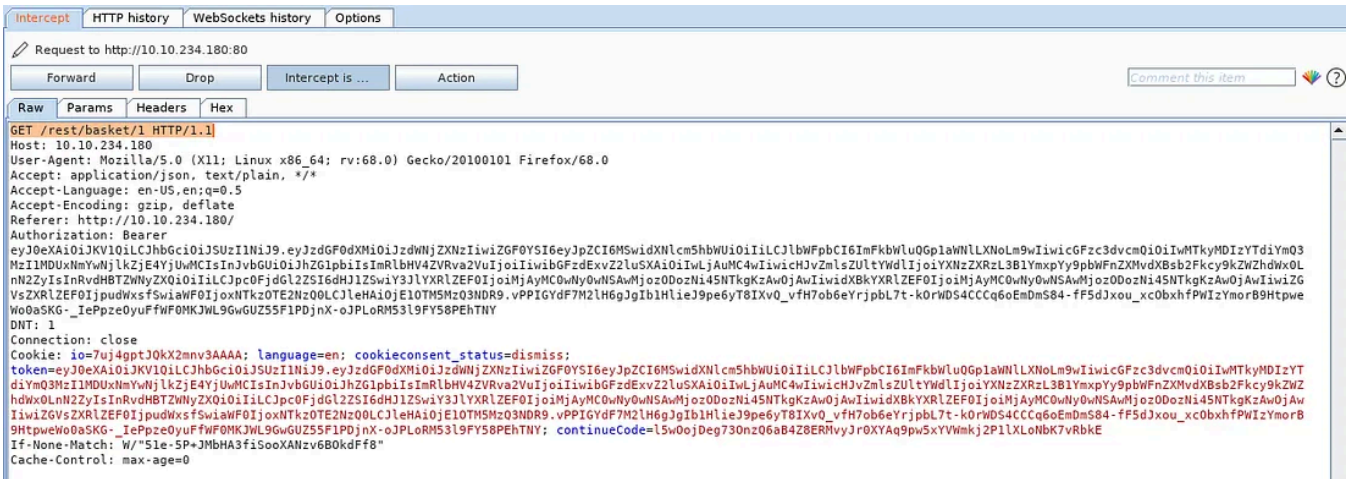
I guessed the administrator's page as /administrator which is true but none of them worked because I was not admin back at the time. So what need to do is go and change user as admin and change URL as http://MACHINE_IP/#/administration. You'll get the flag when you received the page.

Answer: 946a799363226a24822008503f5d1324536629a0

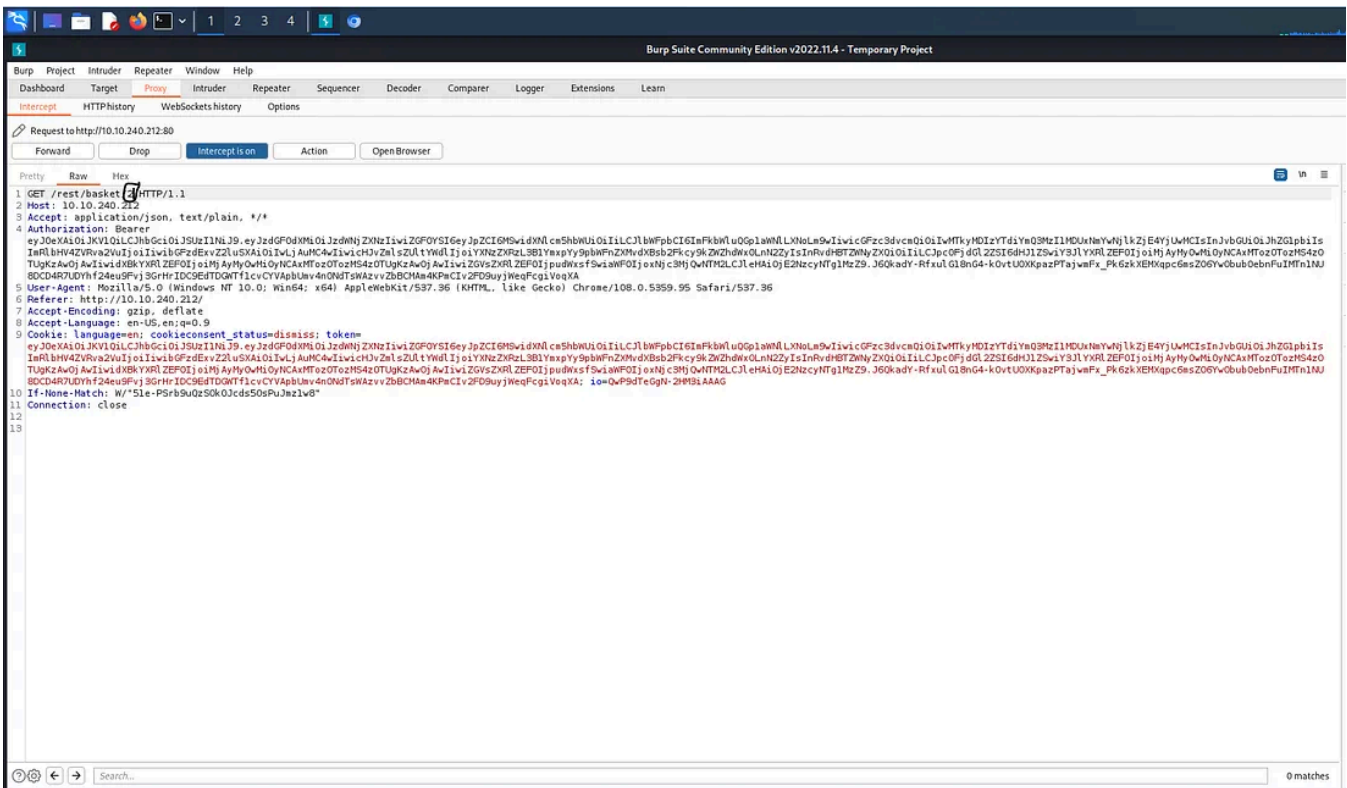
Question #2: View another user's shopping basket!

Login to the Admin account and click on 'Your Basket'. Make sure Burp is running so you can capture the request!

Forward each request until you see: *GET /rest/basket/1 HTTP/1.1*



Now, we are going to change the number 1 after /basket/ to 2



GET /rest/basket/2 HTTP/1.1

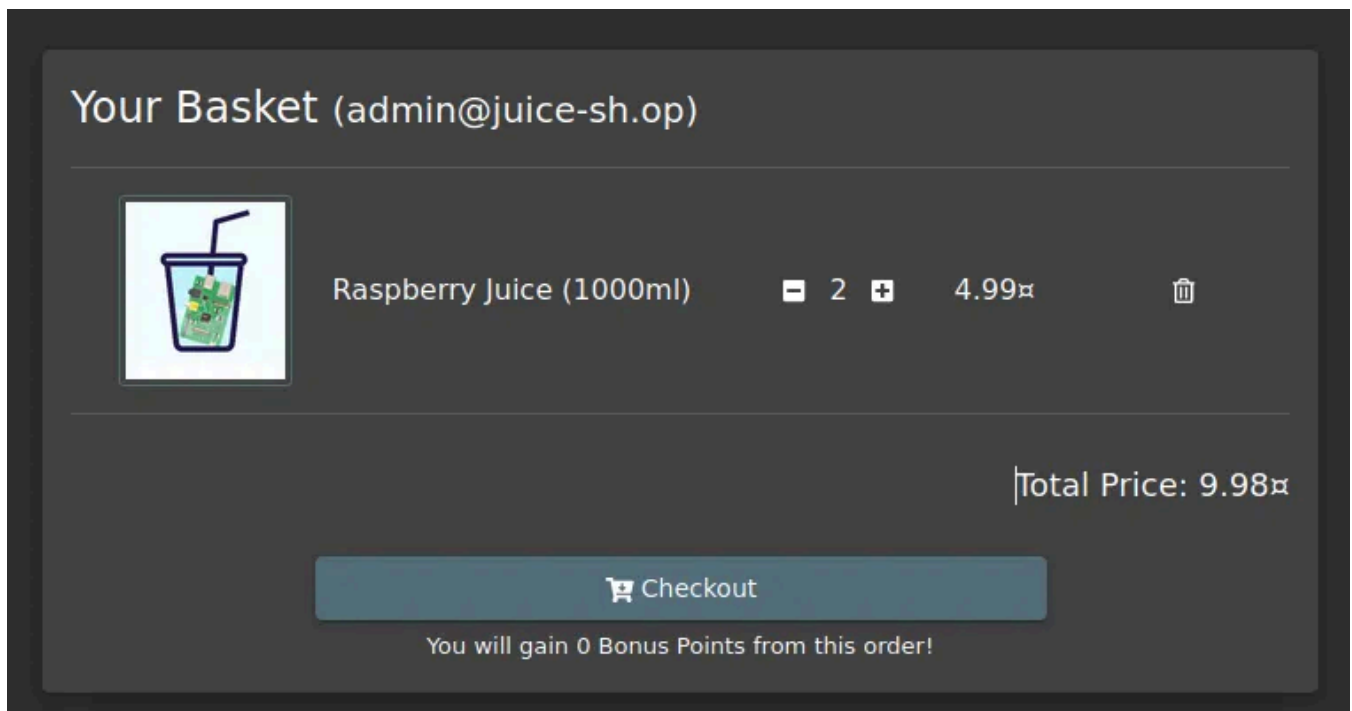
1	2	200			892
2	3	200			892

Request Response

Pretty Raw Render \n Actions ▾

```
11 Connection: close
12
13 {
  "status": "success",
  "data": {
    "id": 2,
    "coupon": null,
    "createdAt": "2021-09-03T04:14:50.698Z",
    "updatedAt": "2021-09-03T04:14:50.698Z",
    "UserId": 2,
    "Products": [
      {
        "id": 4,
        "name": "Raspberry Juice (1000ml)",
        "description": "Made from blended Raspberry Pi, water and sugar.",
        "price": 4.99,
        "deluxePrice": 4.99,
        "image": "raspberry_juice.jpg",
        "createdAt": "2021-09-03T04:14:48.907Z",
        "updatedAt": "2021-09-03T04:14:48.907Z",
        "deletedAt": null,
        "BasketItem": {
          "id": 4,
          "quantity": 2,
          "createdAt": "2021-09-03T04:14:50.699Z",
          "updatedAt": "2021-09-03T04:14:50.699Z",
          "BasketId": 2,
          "ProductId": 4
        }
      }
    ]
  }
}
```

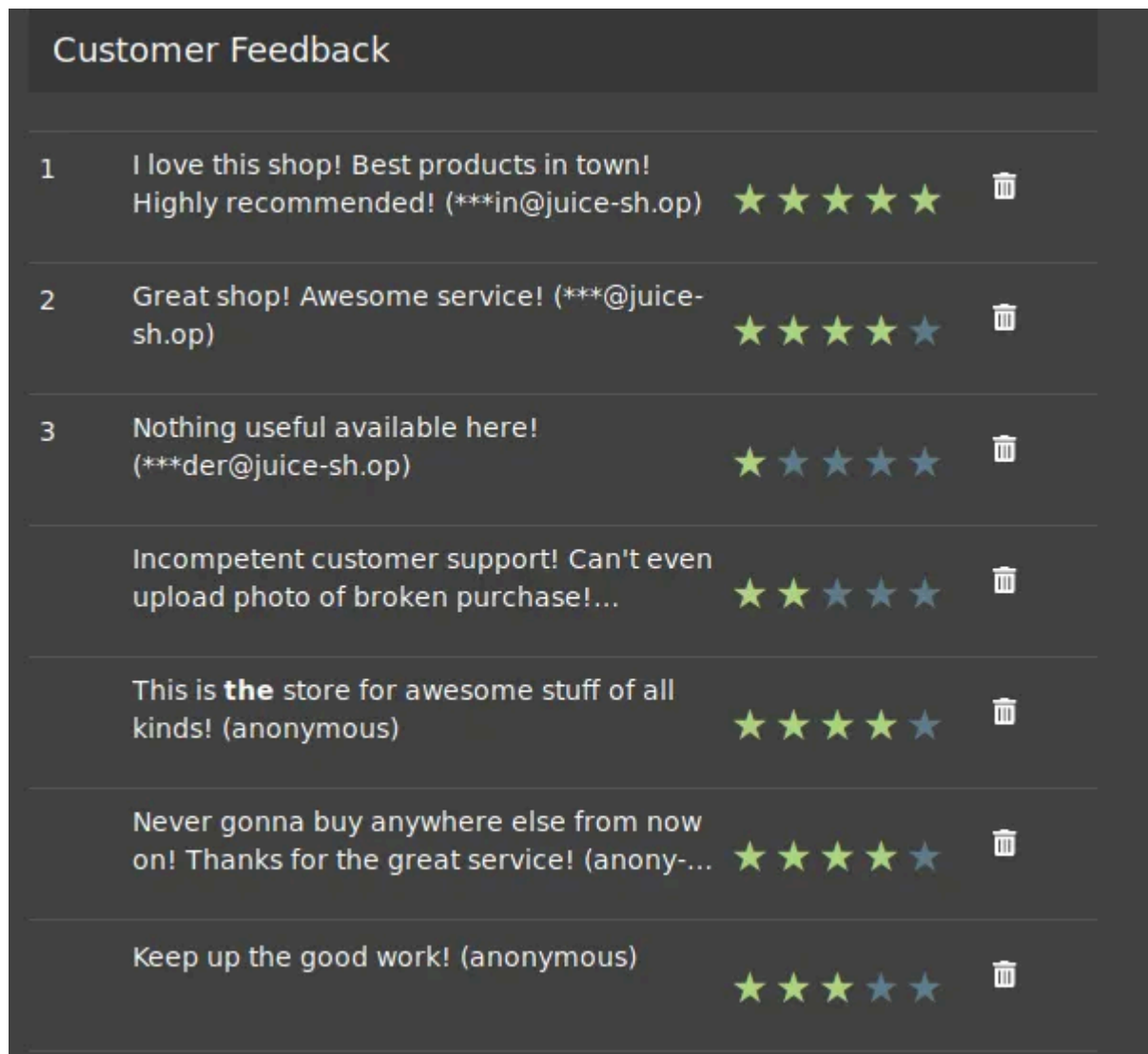
It will now show you the basket of UserID 2. You can do this for other UserIDs as well, provided that they have one!



Answer: 41b997a36cc33fbe4f0ba018474e19ae5ce52121

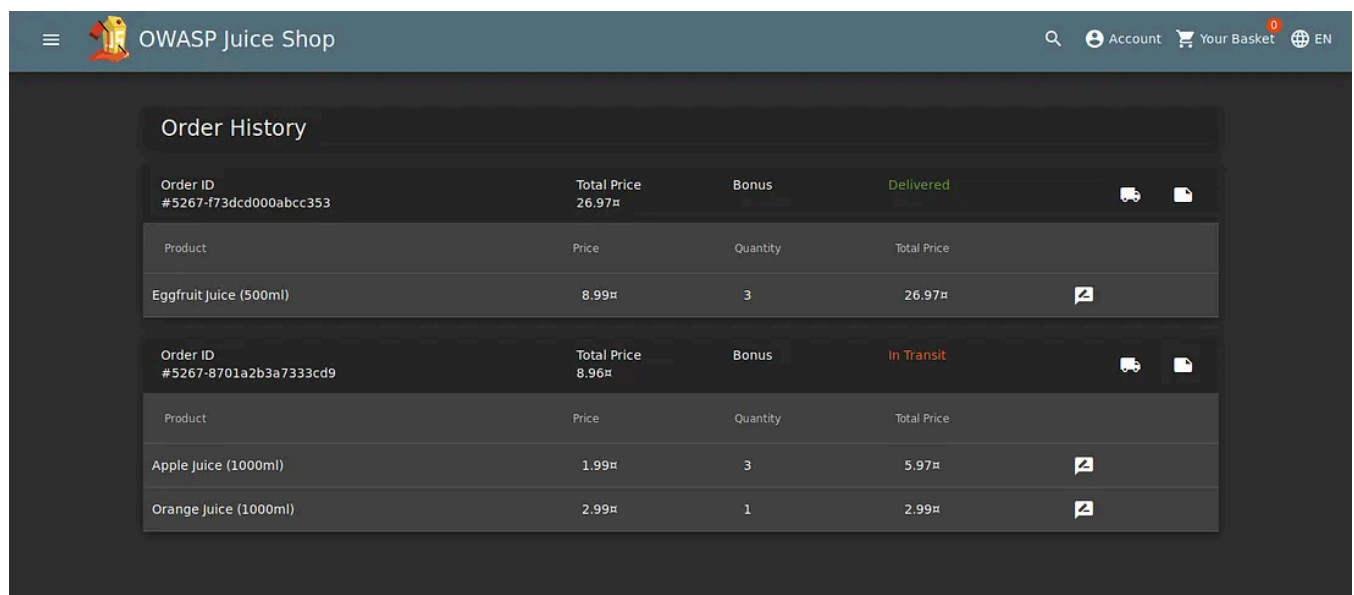
Question #3: Remove all 5-star reviews!

Navigate to the <http://machineip/#/administration> page again and click the bin icon next to the review with 5 stars!



Answer: 50c97bcce0b895e446d61c83a21df371ac2266ef

Task 7 Where did that come from?



XSS or Cross-site scripting is a vulnerability that allows attackers to run javascript in web applications. These are one of the most found bugs in web applications. Their complexity ranges from easy to extremely hard, as each web application parses the queries in a different way.

There are three major types of XSS attacks:

DOM XSS (*Document Object Model-based Cross-site Scripting*) uses the HTML environment to execute malicious javascript. This type of attack commonly uses the `<script></script>` HTML tag.

Persistent XSS is javascript that is run when the server loads the page containing it. These can occur when the server does not sanitize the user data when it is **uploaded** to a page. These are commonly found in blog posts.

Reflected XSS is javascript that is run on the client-side end of the web application. These are most commonly found when the server doesn't sanitize **search** data.

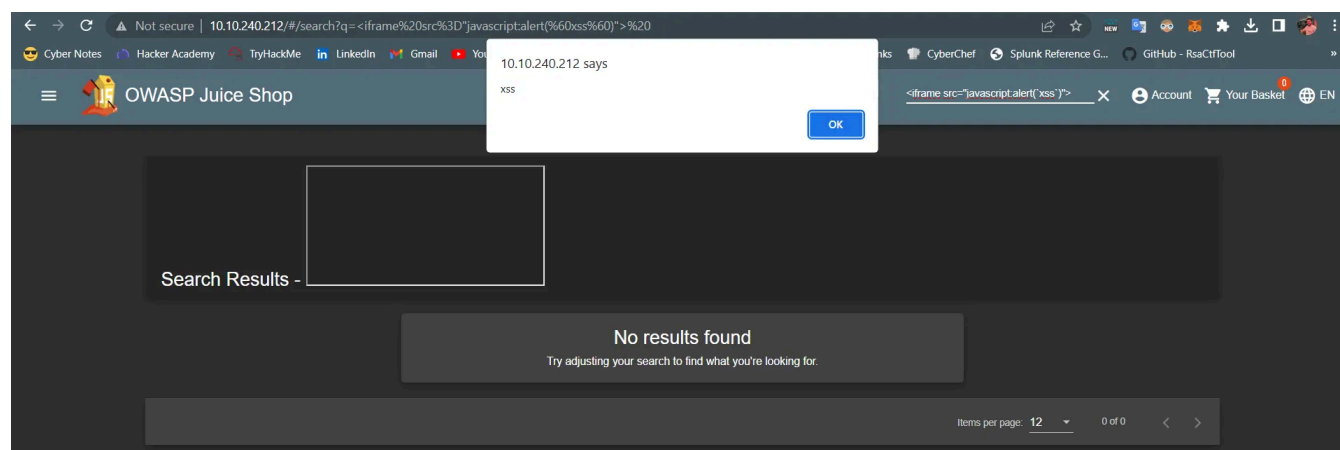
Question #1: Perform a DOM XSS!



We will be using the iframe element with a javascript alert tag:

```
<iframe src="javascript:alert(`xss`)">
```

Inputting this into the **search bar** will trigger the alert.



Note that we are using **iframe** which is a common HTML element found in many web applications, there are others that also produce the same result.

This type of XSS also called XFS (Cross-Frame Scripting), is one of the most common forms of detecting XSS within web applications.

Websites that allow the user to modify the **iframe** or other DOM elements will most likely be vulnerable to XSS.

Why does this work?

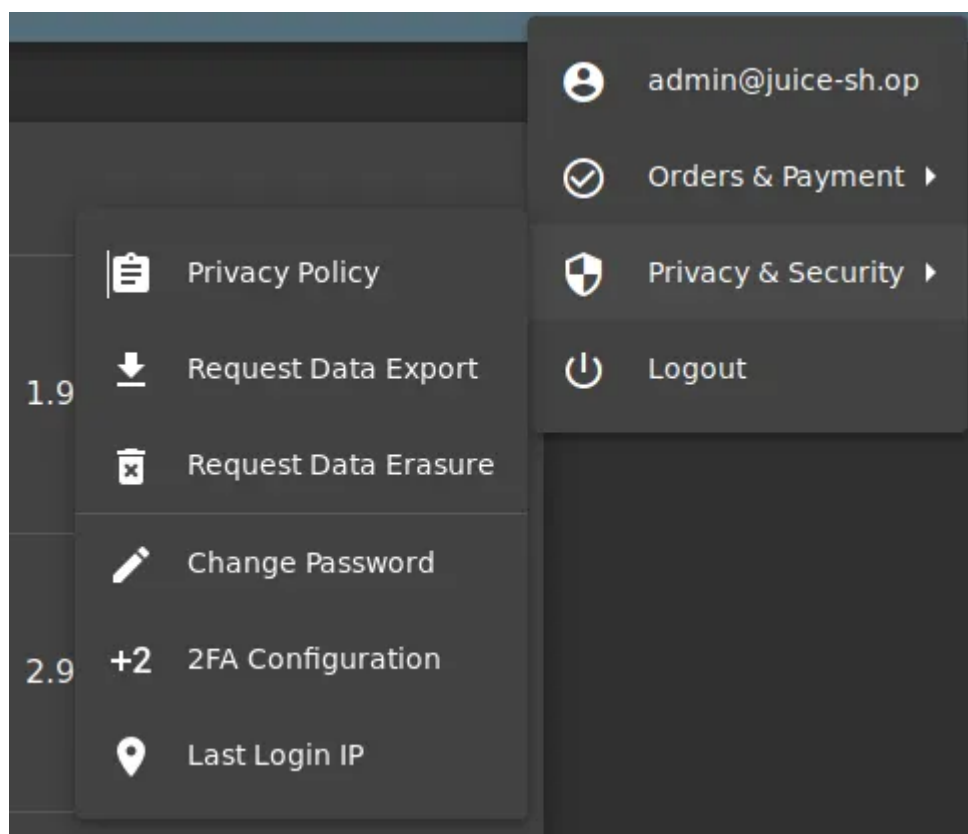
It is common practice that the search bar will send a request to the server which will then send back the related information, but this is where the flaw lies. Without correct input sanitation, we are able to perform an XSS attack against the search bar.

Answer: 9aaf4bbea5c30d00a1f5bbcfce4db6d4b0efe0bf

Question #2: Perform a persistent XSS!

First, log in to the **admin** account.

We are going to navigate to the “**Last Login IP**” page for this attack.



It should say the last IP Address is 0.0.0.0 or 10.x.x.x

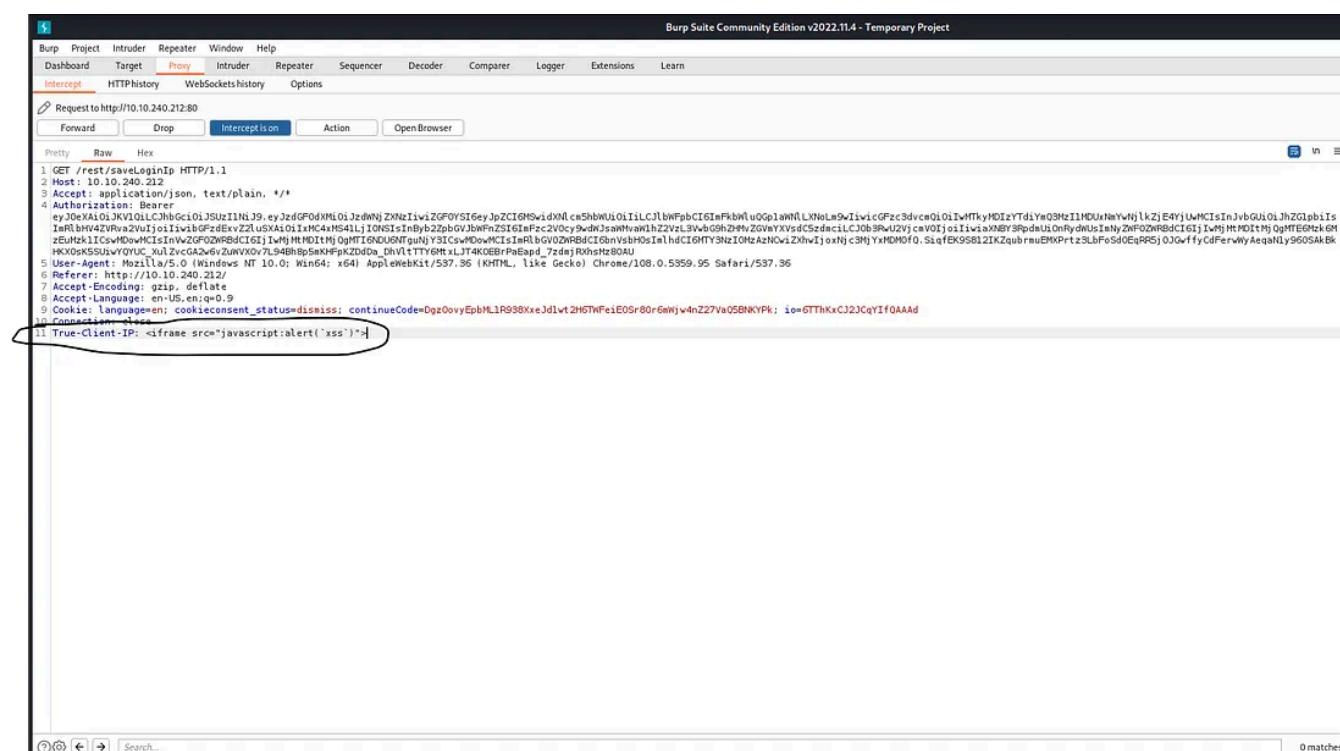
As it logs the 'last' login IP we will now logout so that it logs the 'new' IP.

Intercept is on

Make sure that Burp intercept is on, so it will catch the logout request.

We will then head over to the Headers tab where we will add a new header:

True-Client-IP <iframe src="javascript:alert(`xss`)">



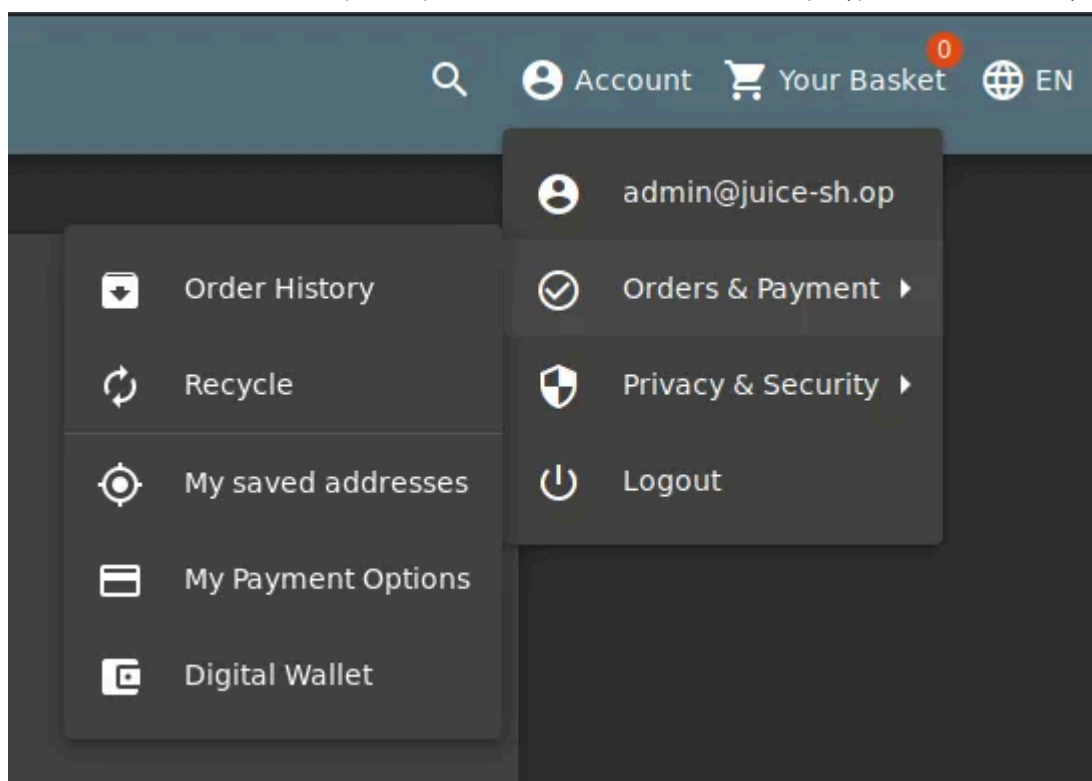
And if you forward the request and log in as admin again you'll see the alert box when you enter the Last IP section.

Answer: 149aa8ce13d7a4a8a931472308e269c94dc5f156

Question #3: Perform a reflected XSS!

First, we are going to need to be on the right page to perform the reflected XSS!

Login into the admin account and navigate to the 'Order History' page.

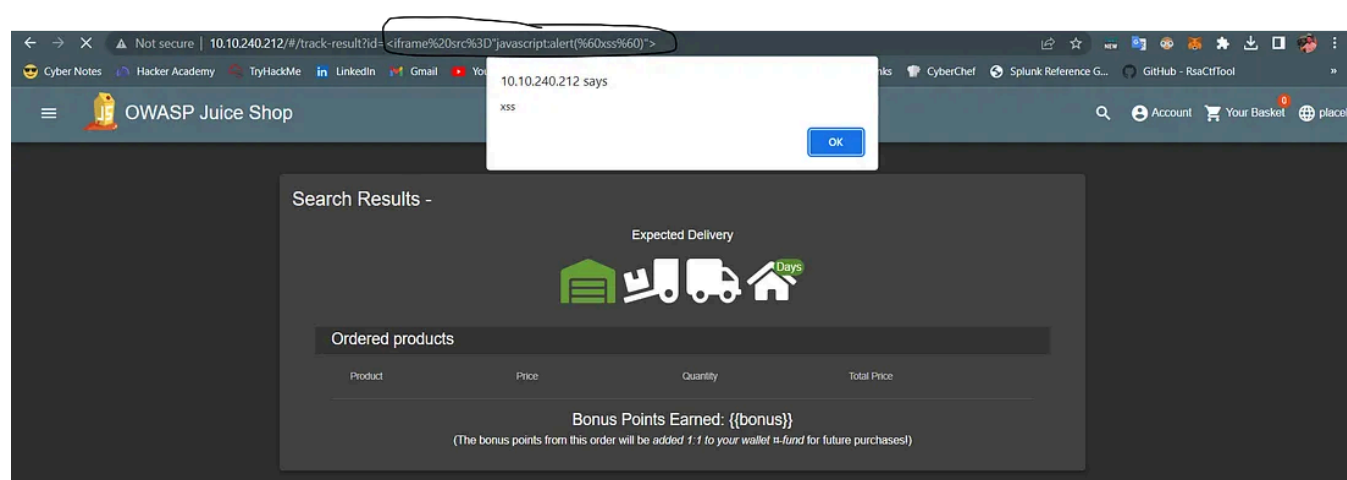


From there you will see a “Truck” icon, clicking on that will bring you to the track result page. You will also see that there is an id paired with the order.

```
192.168.1.2/#/track-result?id=5267-f73dcd000abcc353
```

We will use the iframe XSS, `<iframe src="javascript:alert(`xss`)">`, in the place of the 5267-f73dcd000abcc353

After submitting the URL, refresh the page and you will then get an alert saying XSS!



Answer: 23cefee1527bde039295b2616eeb29e1edc660a0

Task 8 Exploration!

Access the `/#/score-board/` page

Just append the directory to the main IP of the server, and press enter.

```
http:// MACHINE_IP/ /#/score-board
```

Answer: 7efd3174f9dd5baa03a7882027f2824d2f72d86e

Hope you enjoyed it as I enjoyed it! Here is the link for the room;

TryHackMe | OWASP Juice Shop

This room uses the Juice Shop vulnerable web application to learn how to identify and exploit common web application...

tryhackme.com

Happy learning :)

Tryhackme Walkthrough

Tryhackme

Owasp Top 10

Cybersecurity

Pentesting



Follow

Written by Ramazan Salman

58 followers · 47 following

Security Engineer

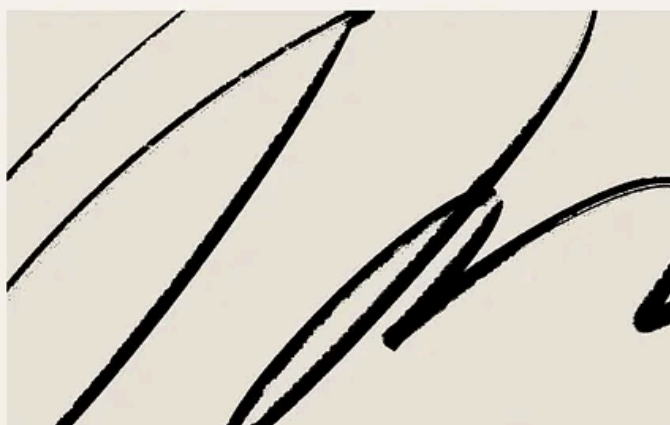
No responses yet



Write a response

What are your thoughts?

Más de Ramazan Salman



Ramadán Salman

Código de recomendación de Fuse Energy 2026 – RAMAZAN65568 – Gana hasta 150 £ en crédito de energía.

RAMAZAN65568 es un código de referencia activo de Fuse Energy que te puede dar la oportunidad de ganar un crédito de energía de entre 25 y 150 libras esterlinas al cambiar de...

3 de marzo

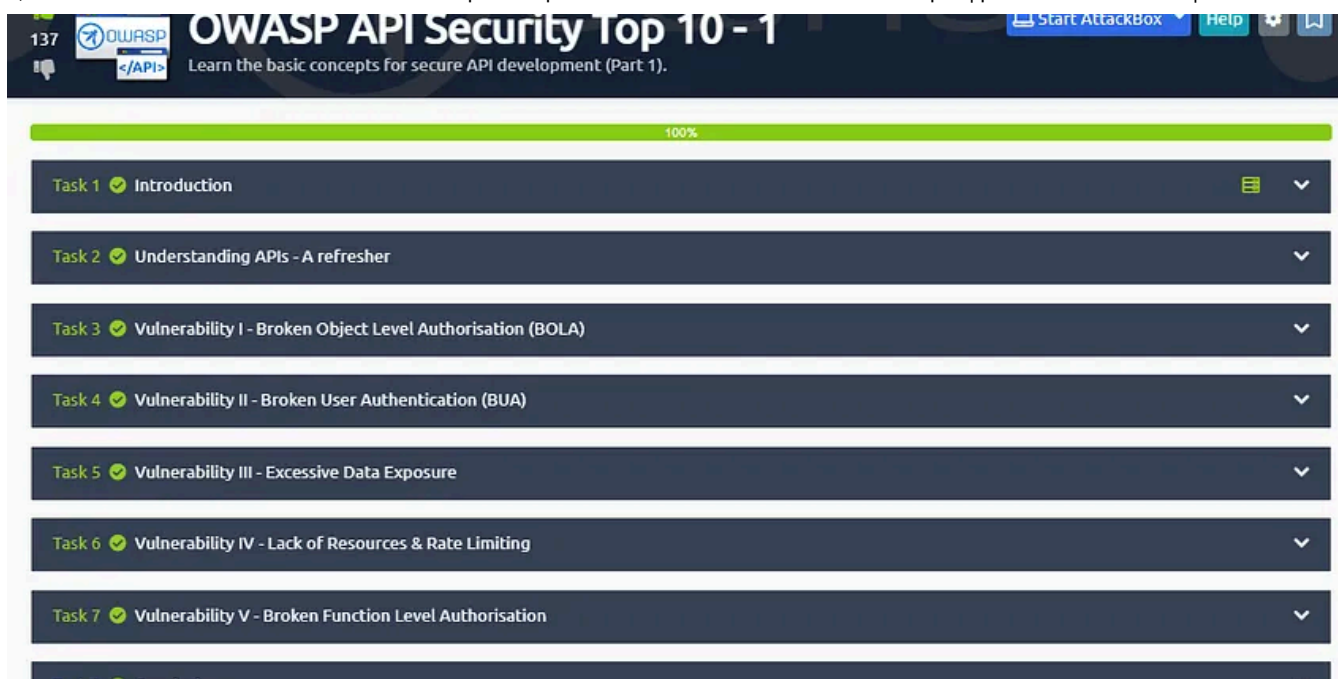


2



3



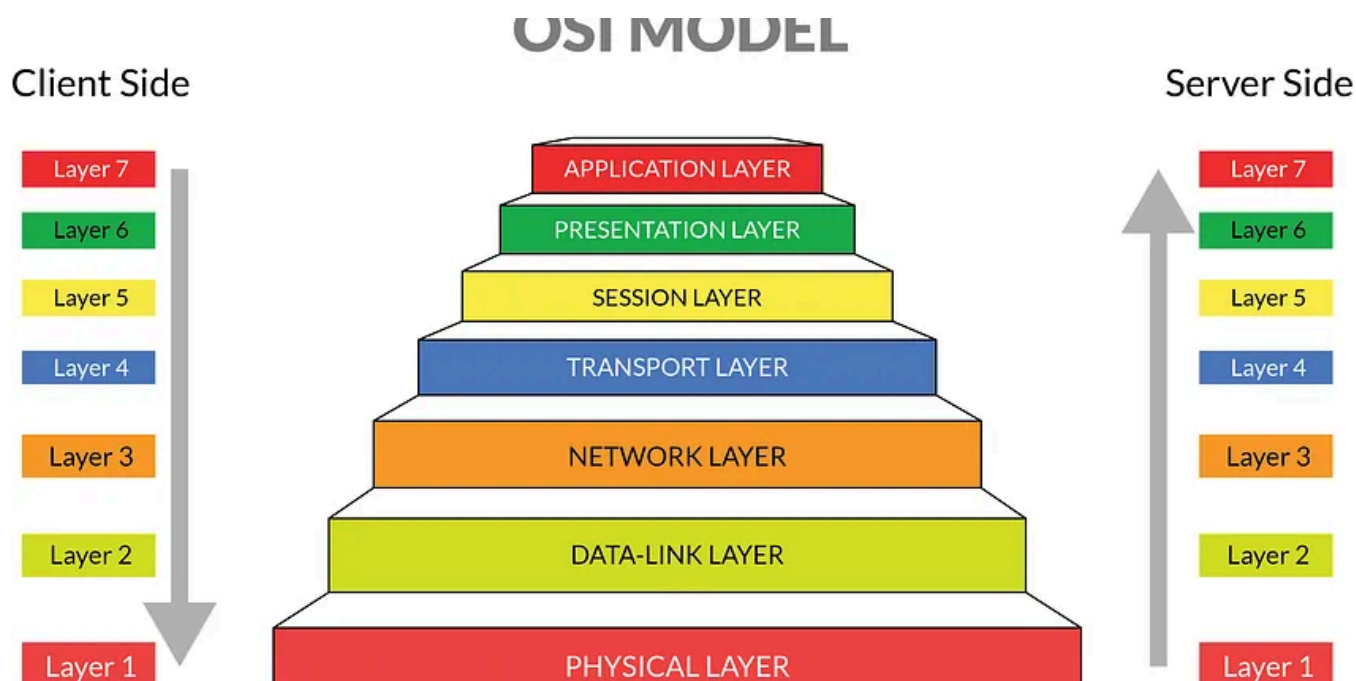


 Ramadán Salman

OWASP API Security Top 10 – 1 de TryHackMe:

Puedes obtener más información sobre la API:

28 de enero de 2023



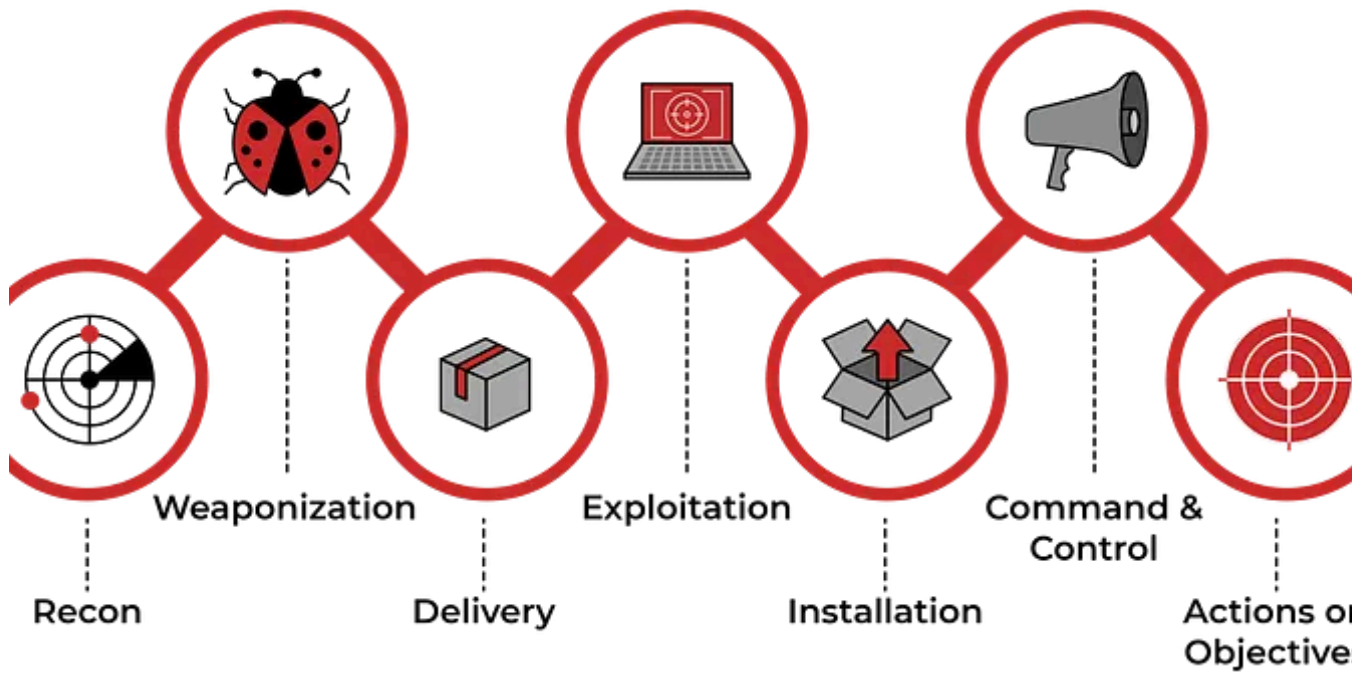
 Ramadán Salman

Modelo OSI: Modelo de interconexión de sistemas abiertos

Tarea 1 ¿Qué es el modelo OSI?

10 de marzo de 2023  3





 Ramadán Salman

Gestión de incidentes con Splunk — [Informe] —

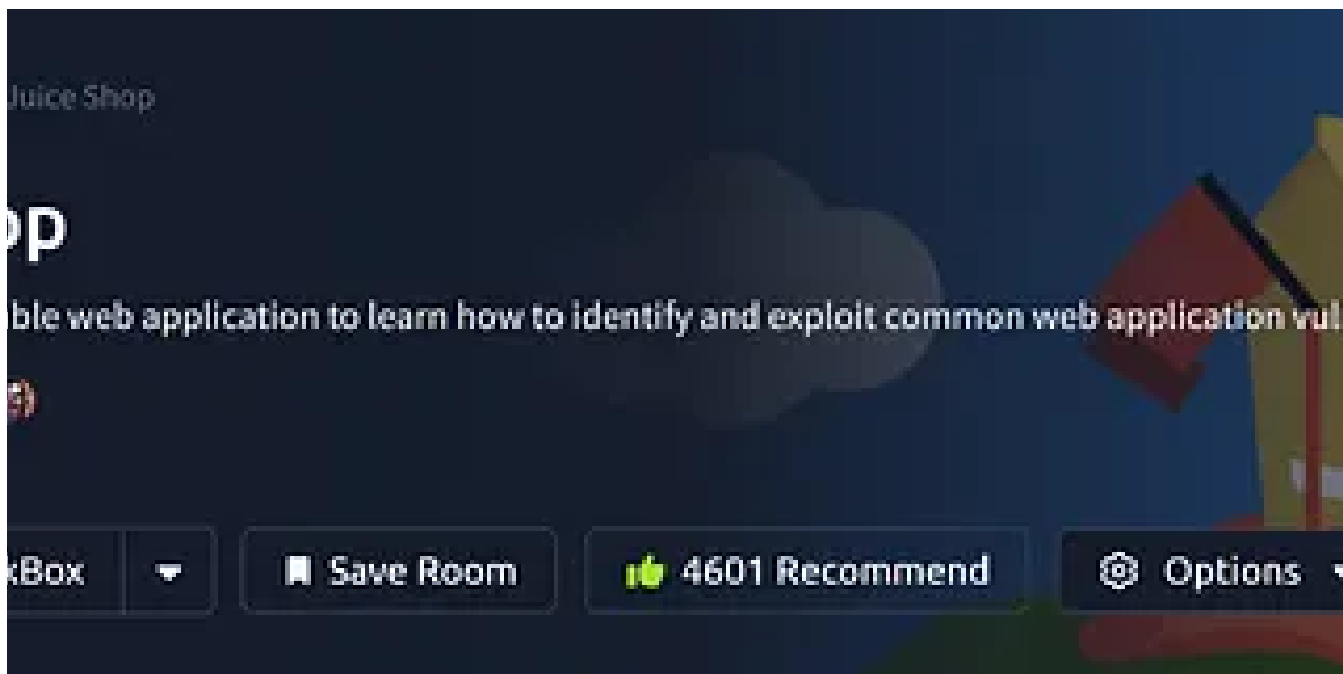
Esta sala cubre un escenario de manejo de incidentes usando Splunk. Un incidente desde una perspectiva de seguridad es “cualquier evento o acción que tenga una...

28 de febrero de 2023  5



Ver todo de Ramazan Salman

Recomendado por Medium

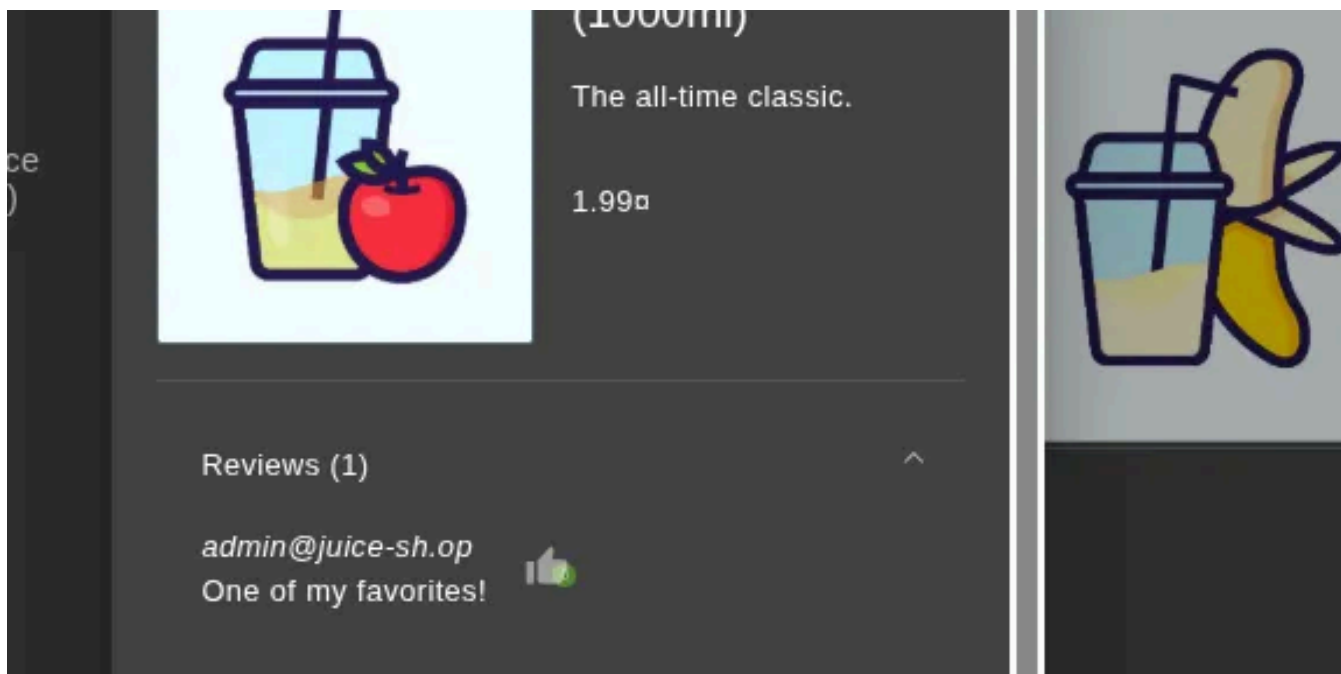


 Yousef Amr

OWASP Juice Shop TryHackMe - Guía práctica 🍹 Tutorial de hacking ético por Yousef Amr | SQLi, XSS...

Escrito por Yousef Amr (LinkedIn, TryHackMe)

26 de octubre de 2025

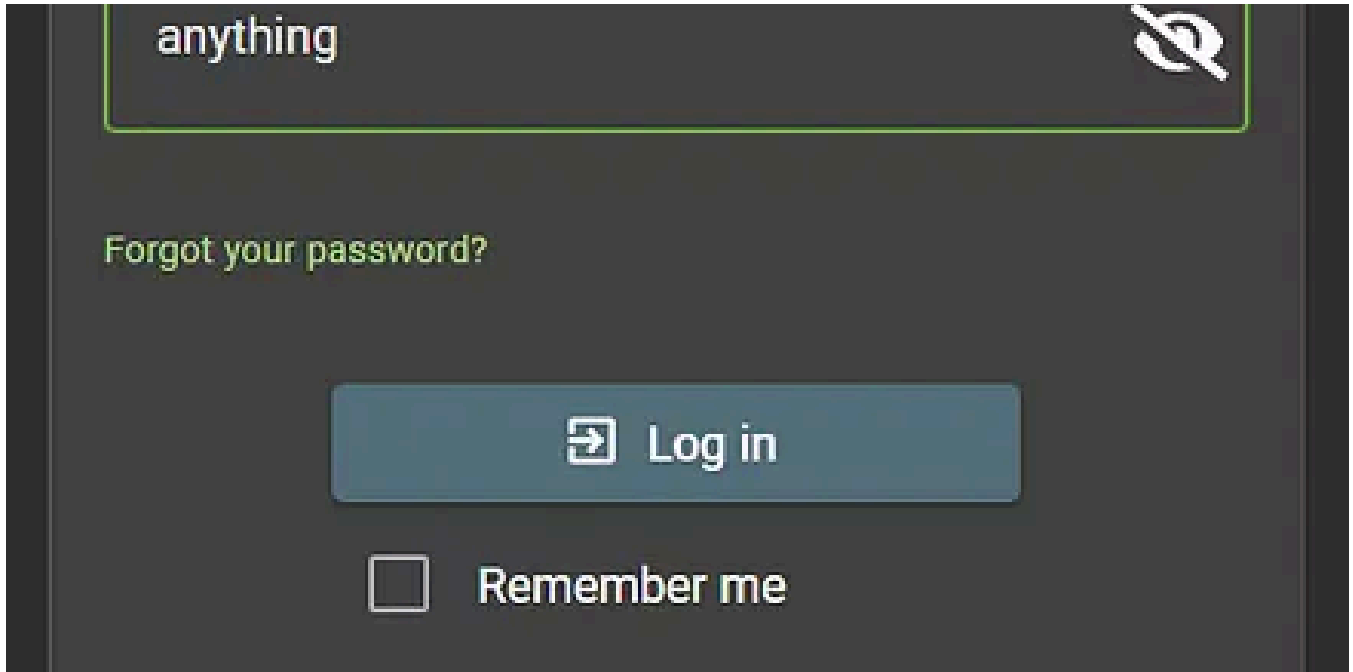


 Hasnainabid

🍹 Tienda de zumos OWASP — Artículo

Sala: OWASP Juice Shop Plataforma: TryHackMe Autor/Estudiante: Hasnain Abid (reemplazar con tu nombre) Fecha: (insertar fecha) Dificultad...

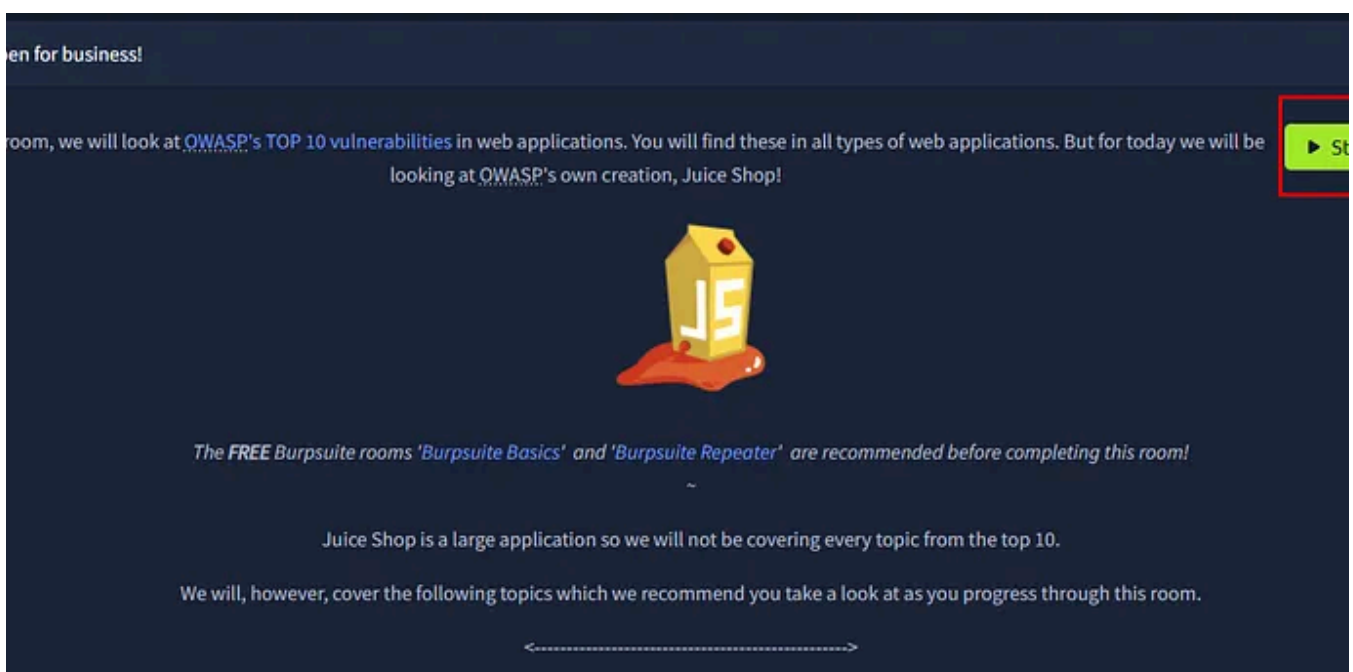
6 de noviembre de 2025

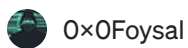
 En Stackademic por Srividya Sundaravadivelu

Mis experimentos con OWASP Juice Shop: qué hackeé, qué no pude y qué aprendí.

Este artículo se publicó originalmente en NumpyNinja Academy y se ha vuelto a publicar aquí en Medium para un público más amplio.

★ 21 de octubre de 2025





O×OFoysal

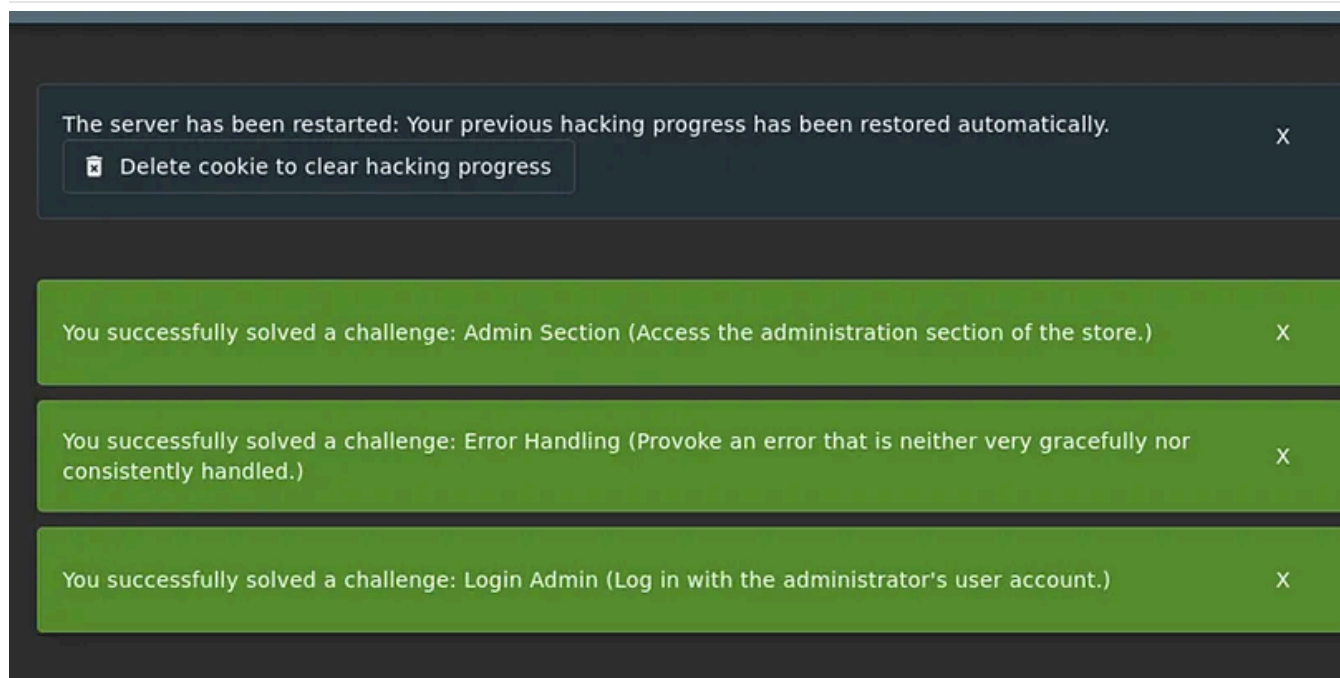
OWASP Juice Shop — Informe de TryHackMe (2025, detallado)

“¿Me podría dar un cartón de zumo ‘vulnerable’, por favor?”

12 de noviembre de 2025



2



Kshitij Gupta

Pruebas de seguridad de aplicaciones web con OWASP Juice Shop: una evaluación práctica para principiantes.

Por: Kshitij Gupta, pasante de ciberseguridad — Futuros pasantes

10 de diciembre de 2025



	Initiator	Type	Transferred	
	document	html	1.86 KB	5
	stylesheet	css	32.06 KB	1
	stylesheet	css	118.60 KB	1
	stylesheet	css	6.51 KB	6
	script	js	87.64 KB	8
	script	js	36.44 KB	3
	script	js	668 B	4
	account:1 (xhr)	json	363 B	7
	FaviconLoader.png (img)	html	1.16 KB	2
	onloadoff.js (img)	html	1.16 KB	3

 Temitayo Azeez

IDOR (tryhackme) por Temi.

¿Qué es un IDOR?

9 de noviembre de 2025



Ver más recomendaciones